EXAMEN · SDD CON IA

NexoEntrega 360

Informe técnico y evidencias

Especificaciones · Arquitectura · Validación · Equipo

EDICIÓN PROVISIONAL PARA REVISIÓN

14 de octubre de 2026

Cantillo Carolina · 20231153656

Castro Edier · 202311254074

Conde José · 202321256268

Vega José · 202321256198

Código de referencia

dd806db9b47abff9dd30fb393761941245fed007

Sin aceptación final ni aprobación humana implícita.

Índice

1. Entrega identificada y estado del proyecto **4**

1.1 Qué funciona y qué falta . . . 4

2. Cinco historias de usuario y especificaciones **5**

SPEC-01 · Identidad y permisos . . . 6

SPEC-02 · Creación y envío de solicitudes . . . 11

SPEC-03 · Inventario y transiciones . . . 16

SPEC-04 · Consultas y auditoría . . . 22

SPEC-05 · Asistente IA . . . 27

3. Arquitectura, datos y contratos **33**

3.1 Estructura y límites . . . 33

3.2 Diagramas y modelo de datos . . . 33

3.3 Contrato HTTP integrado . . . 34

3.4 Decisiones de arquitectura . . . 35

ADR-001 Estructura y límites: Laravel y PostgreSQL . . . 35

ADR-002 Estrategia transaccional, concurrencia e idempotencia . . . 37

ADR-003: Autenticación, Sesiones y Aislamiento Multitenant (ORG-A / ORG-B) . . . 42

ADR-004 Integración del asistente de IA y degradación . . . 43

4. Uso crítico de IA y verificación **47**

AI-001-cotejo-oficial-g1 . . . 47

AI-002-escenarios-inventario . . . 48

AI-003-revision-ia-seguridad . . . 49

AI-004-diseno-ia-g2 . . . 51

AI-005-transacciones-g2 . . . 53

AI-006-revisiones-g2-vega . . . 54

AI-007-frontend-provisional . . . 55

5. Validación, trazabilidad y resultados **57**

5.1 Defecto observado y corrección . . . 57

5.2 Trazabilidad SPEC frente a código . . . 57

6. Riesgos y controles **60**

7. Ejecución reproducible y recuperación **61**

Ejecución y entrega provisional . . . 61

7.1 Corrección de auditoría en la instancia local 62

8. Aceptación y pendientes verificables **63**

Acta provisional: entrega no aceptada como final 63

Coordinación de la entrega 63

9. Participación y evidencias del equipo **65**

Participación y revisión: evidencia, no atribución por código generado 65

Fuentes y control de edición 65

1. Entrega identificada y estado del proyecto

NexoEntrega 360 es un sistema académico para coordinar la distribución comunitaria de kits en dos organizaciones de Barranquilla. Este informe reúne especificaciones, arquitectura, contratos, uso de IA, resultados y participación, siguiendo los nueve apartados del anexo oficial 09.

VERSIÓN PROVISIONAL PARA REVISIÓN. No se declara aprobado G1/G2 ni aceptada la entrega. Las decisiones humanas pendientes y los requisitos sin evidencia se identifican expresamente.

Elemento	Identificación
Repositorio	https://github.com/josemanuelcondeacosta-lang/nexoentrega-360-sdd-ia
Código de esta edición	dd806db9b47abff9dd30fb393761941245fed007
Base de pruebas anteriores	f33183aa72c261bb513cf8aada1113605b461262
Ejecución local	http://127.0.0.1:8000 — requiere Docker; no es URL pública para el docente
release-examen / baseline-v1	No creados como aceptación final. La identificación de paquetes provisionales anteriores no acredita cierre.
Originales oficiales	docs/examen-oficial/originales/ y docs/examen-oficial/anexos/
Procedencia editorial	Edición asistida por Codex. No cambia requisitos ni atribuye firmas o trabajo humano.

1.1 Qué funciona y qué falta

La aplicación provisional incluye sesiones, ocho cuentas ficticias, formulario de solicitudes, transiciones por rol, reserva transaccional, idempotencia, inventario, listados, tablero e historial. El asistente integrado utiliza únicamente fallback determinista, visible como tal; no se ha demostrado una salida de un LLM real en esta aplicación.

Pendientes de cierre: revisión humana de las versiones correspondientes, proveedor IA y validación estricta completa, carga exigida, pruebas de todos los criterios, restauración y aceptación manual. Adelantar implementación por instrucción del coordinador no subsana la revisión previa requerida por el examen.

Fuente: docs/examen-oficial/anexos/09_pdf-delivery-template.md

2. Cinco historias de usuario y especificaciones

Las siguientes especificaciones proceden de los JSON generados a partir de las fuentes Markdown. Se conserva el contenido funcional y el estado declarado. Los 73 criterios son objetivos de aceptación; no deben interpretarse como 73 pruebas superadas.

Especificación	Versión / criterios	Revisión
SPEC-01 · Identidad y permisos	0.4-draft / 14	Pendiente según fuente; ver registro humano por SHA
SPEC-02 · Creación y envío de solicitudes	0.3-draft / 11	Pendiente según fuente; ver registro humano por SHA
SPEC-03 · Inventario y transiciones	0.4-draft / 17	Pendiente según fuente; ver registro humano por SHA
SPEC-04 · Consultas y auditoría	0.3.2-draft / 14	Pendiente según fuente; ver registro humano por SHA
SPEC-05 · Asistente IA	0.4-draft / 17	Pendiente según fuente; ver registro humano por SHA

SPEC-01 · Identidad y permisos

Versión: 0.4-draft. Estado: Borrador cotejado con el enunciado oficial; pendiente de revisión humana independiente

HU-01 — Como usuario de una organización con rol solicitante, coordinador, bodega o auditor, quiero iniciar y cerrar sesión con una cuenta sembrada y operar solo dentro de los permisos de mi rol y de mi organización, para nadie lea ni modifique recursos de otra organización ni ejecute acciones que su rol no permite.

Autenticación con cuentas sembradas, resolución de identidad en el servidor, matriz de permisos por rol aplicada en cada operación y aislamiento por organización con respuestas 401, 403 y 404 que no revelan datos. Enunciado §2.

Requisitos relacionados: RF01, RF02, RNF01, RNF05, RNF06.

Actores

• Solicitante, Coordinador, Bodega y Auditor de ORG-A u ORG-B

• API del sistema, que resuelve identidad, organización y rol

Alcance

• Inicio y cierre de sesión con cuentas sembradas; sesión o token justificado en ADR-003

• Hash apropiado de contraseñas y ausencia de secretos en el repositorio

• Ocho cuentas ficticias: una por rol en cada organización, regenerables por seed

• Matriz de permisos aplicada en el servidor y aislamiento por organización en toda operación

• Respuestas, errores y logs sin datos de otra organización ni secretos

Fuera del alcance

• Creación masiva de usuarios, recuperación de contraseña y proveedores de identidad externos (no exigidos, enunciado §2)

• Selector de rol como reemplazo del inicio de sesión (prohibido por RF01)

Entradas y validaciones

Entrada	Tipo	Validación
login	string; correo ficticio del seed, por ejemplo org-a-solicitante@example.test	Obligatorio Debe corresponder a una cuenta sembrada; el error no revela si la cuenta existe
password	string	Obligatorio Se verifica contra el hash almacenado Nunca se registra ni se devuelve
credencial de sesión	cookie de sesión o token bearer según ADR-003	Debe estar vigente y no revocada en cada petición Ausente, inválida o revocada produce 401
organización y rol	derivados de la identidad autenticada	Cualquier organizationId o role enviado por el navegador se ignora y no autoriza
identificador de recurso	string	Se busca solo dentro de la organización autenticada Inexistente o de otra organización produce 404

Proceso

• Recibir login y contraseña, buscar la cuenta y verificar la contraseña contra su hash

• Si son válidas, crear una sesión o token revocable; si no, responder 401 genérico sin crear sesión

• En cada petición resolver identidad, organización y rol desde la credencial; sin credencial válida responder 401

• Resolver el recurso filtrando por la organización de la identidad; si no existe en ella responder 404

• Evaluar el permiso del rol sobre la operación según la matriz del enunciado; si está prohibida responder 403 sin efectos

• Ejecutar la operación autorizada y registrar logs estructurados con correlationId, sin contraseñas, hashes ni tokens

• En logout revocar la credencial; cualquier uso posterior recibe 401

Reglas de negocio

• Matriz oficial, enunciado §2. Solicitante: crear y editar sus borradores, enviar su solicitud, consultar las propias y cancelar las propias en ENVIADA o RESERVADA

• Coordinador: consultar solicitudes de su organización, reservar ENVIADA, registrar ENTREGADA sobre DESPACHADA, usar y aprobar resúmenes de IA

• Bodega: consultar inventario y solicitudes de su organización y despachar RESERVADA

• Auditor: consultar solicitudes, inventario y auditoría de su organización; no modifica datos ni invoca el asistente

• Una operación no listada para un rol se deniega: 403 si el recurso es de su organización. Según respuesta afirmativa de la profesora reportada por Conde José (CL-16/17/18), el Coordinador lee inventario e historial de su organización y el Solicitante lee historial/tablero de sus propias solicitudes sin inventario. Bodega no recibe auditoría. Evidencia original pendiente; revisión renovada requerida

• Los permisos se comprueban en el servidor en cada operación; ocultar un botón no es autorización

• La organización y el rol provienen de la identidad autenticada; un valor enviado por el navegador no autoriza cambiar de organización

• No se admite un selector de rol como reemplazo del inicio de sesión

• Contraseñas guardadas con hash apropiado; sin claves privadas ni secretos en el repositorio

• Una cuenta por rol en cada organización con credenciales ficticias publicadas para evaluación y forma documentada de regenerarlas

• Las reglas 401, 403 y 404 se aplican también al contenido de respuestas, errores y logs

Casos límite

• Contraseña errónea y login inexistente con respuesta indistinguible

• Credencial revocada o expirada reutilizada

• Rol u organización adulterados en cuerpo, parámetros o encabezados

• Usuario de ORG-A que conoce el identificador B-001 de ORG-B

• Llamadas directas a la API sin pasar por la interfaz

• Auditor que intenta una escritura dentro de su organización

• Solicitante que consulta la solicitud de otro solicitante de su organización: 403 por la regla de acción prohibida sobre recurso propio de la organización

Supuestos registrados

• Sesión de servidor revocable como propuesta; la elección sesión o token se justifica en ADR-003 (G2)

• Algoritmo y parámetros de hash se fijan en ADR-003

• Los logins de las ocho cuentas son los del anexo fixture-scenarios.json

Preguntas registradas

• CL-14: expiración de sesión, protección CSRF y política de contraseña (decisión del equipo en ADR-003)

• CL-16, CL-17 y CL-18: respuesta afirmativa reportada por el coordinador; fecha/canal y evidencia original pendientes, nueva revisión humana requerida

Dependencias

• Seed de cuentas y migraciones (RNF04, SPEC-04)

• Las SPEC-02 a SPEC-05 aplican esta matriz de permisos a sus operaciones

Salidas

Condición	Resultado
Credenciales válidas	200 con cuenta, rol y organización, sin hash; se crea sesión o token
Contraseña errónea o cuenta inexistente	401 con el mismo mensaje en ambos casos; no se crea sesión
Logout	204; la credencial queda revocada de forma persistente
Petición sin identidad válida	401 sin datos de negocio
Recurso inexistente o de otra organización	404 sin revelar existencia ni datos
Acción prohibida para el rol sobre un recurso de su organización	403 sin cambios persistidos

Criterios de aceptación

AC-01-01 · negativo · RF01, RNF01

Dado: un cliente sin sesión ni token

Cuando: consulta el listado de solicitudes por la API

Entonces: recibe 401 sin datos de solicitudes y no se crea ninguna sesión

AC-01-02 · permiso · RF02, RNF01

Dado: un coordinador de ORG-A autenticado y la solicitud B-001 de ORG-B sembrada

Cuando: consulta B-001 por su identificador

Entonces: recibe 404 con el mismo cuerpo que para un identificador inexistente; la respuesta y el log no contienen datos de B-001

AC-01-03 · permiso · RF02, RNF01

Dado: un auditor de ORG-A autenticado y A-001 en ENVIADA

Cuando: intenta reservar o modificar A-001

Entonces: recibe 403; el estado de A-001, el inventario y los eventos de auditoría no cambian

AC-01-04 · positivo · RF01

Dado: el seed aplicado con las ocho cuentas ficticias

Cuando: cada cuenta inicia sesión con su contraseña sembrada, ejecuta una operación permitida de su rol y cierra sesión

Entonces: el login responde 200 con rol y organización correctos y sin hash; la operación permitida tiene éxito; el logout responde 204 y la misma credencial recibe 401 después

AC-01-05 · positivo · RF01

Dado: una base recién migrada y sembrada

Cuando: se consultan las cuentas en la base y se lee el runbook

Entonces: existen ocho cuentas distintas, una por rol en ORG-A y en ORG-B, con los logins del anexo; las contraseñas solo están como hash; el runbook publica las credenciales ficticias y el comando que las regenera

AC-01-06 · negativo · RF01, RNF01

Dado: una cuenta existente y un login inexistente

Cuando: se intenta iniciar sesión con contraseña errónea en la primera y con cualquier contraseña en el segundo

Entonces: ambos intentos reciben 401 con el mismo mensaje; no se crea sesión y la respuesta no revela si la cuenta existe

AC-01-07 · permiso · RF02, RNF01

Dado: un solicitante de ORG-A autenticado

Cuando: intenta reservar A-001 de su organización y B-001 de ORG-B enviando organizationId ORG-B y role COORDINADOR adulterados, con sesión y token CSRF válidos

Entonces: la identidad del servidor prevalece: A-001 recibe 403 por rol prohibido y B-001 recibe 404 por organización ajena; ninguna solicitud, stock o evento de éxito cambia

AC-01-08 · negativo · RF01

Dado: una credencial cerrada con logout

Cuando: se reutiliza en cualquier operación

Entonces: recibe 401; la revocación está persistida y no se ejecuta ninguna operación de negocio

AC-01-09 · permiso · RF02, RNF01

Dado: usuarios autenticados de ORG-A y recursos sembrados de ORG-B

Cuando: ejecutan dos lecturas cruzadas, por ejemplo detalle de B-001 y su auditoría, y dos escrituras cruzadas, por ejemplo reservar y despachar B-001

Entonces: las cuatro reciben 404; solicitudes, inventario y auditoría de ORG-B quedan idénticos según snapshot antes y después

AC-01-10 · fallo · RNF01, RNF06

Dado: respuestas y logs producidos por login correcto, login fallido, 401, 403, 404 y un error interno controlado

Cuando: se inspeccionan

Entonces: los logs son estructurados con correlationId y ni logs ni respuestas contienen contraseñas, hashes, tokens ni secretos

AC-01-11 · negativo · RF01

Dado: la interfaz web y la API sin sesión iniciada

Cuando: se intenta entrar al flujo eligiendo un rol o llamando a una operación sin credencial

Entonces: la interfaz solo ofrece inicio de sesión con credenciales y no existe selector de rol que conceda acceso; la API responde 401

AC-01-12 · negativo · RF01

Dado: el repositorio en el commit evaluado

Cuando: se ejecuta la detección de secretos documentada en CI

Entonces: no se encuentran claves privadas, contraseñas reales ni secretos; solo existe configuración de ejemplo sin secretos

AC-01-13 · positivo · RNF05

Dado: la pantalla de inicio y cierre de sesión a 390 y 1366 px de ancho

Cuando: se opera solo con teclado, incluido un intento con credenciales erróneas

Entonces: no hay desbordamiento horizontal; los campos tienen etiqueta; el error queda asociado al formulario y visible; la verificación manual se registra con navegador y fecha sin afirmar conformidad WCAG total

AC-01-14 · negativo · RF01, RNF01

Dado: sesión cookie válida y solicitud propia BORRADOR; token CSRF ausente o inválido

Cuando: intenta editar por PATCH o enviar por POST sin CSRF válido; repite con token válido y datos correctos

Entonces: sin token válido recibe 419 sin cambio de solicitud/inventario/eventos; con token válido supera CSRF y se aplican validación/autorización normales; también login/logout y escrituras IA exigen CSRF

Fuente: specs/SPEC-01.md

SPEC-02 · Creación y envío de solicitudes

Versión: 0.3-draft. Estado: Borrador cotejado con el enunciado oficial; pendiente de revisión humana independiente

HU-02 — Como solicitante de una organización, quiero crear, editar y enviar una solicitud de kits válida, para el coordinador pueda evaluarla y reservar existencias sin datos incompletos ni inválidos.

Registro de solicitudes con código generado por el sistema, zona, prioridad NORMAL o ALTA, fecha requerida, observaciones opcionales y de 1 a 10 líneas con SKU activos distintos y cantidades enteras de 1 a 500; edición exclusiva del borrador por su dueño y transición BORRADOR a ENVIADA auditada. Enunciado §3.

Requisitos relacionados: RF03, RF04, RF09, RNF01, RNF05.

Actores

• Solicitante dueño de la solicitud

• Coordinador, Bodega y Auditor: sin permiso para crear, editar ni enviar

Alcance

• Crear borrador con cabecera y líneas

• Editar el borrador propio

• Enviar: transición BORRADOR a ENVIADA con evento de auditoría

• Validaciones RF03 en el servidor y mensajes de error por campo

Fuera del alcance

• Reserva, despacho, entrega y cancelación (SPEC-03)

• Listados, filtros y tablero (SPEC-04)

• Eliminación de borradores (no exigida por el enunciado)

Entradas y validaciones

Entrada	Tipo	Validación
zona	string de catálogo	Obligatoria Debe pertenecer al catálogo de zonas definido en CL-01 (propuesta: NORTE, SUR y CENTRO, valores del anexo) Zona desconocida produce 422
prioridad	enum NORMAL o ALTA	Obligatoria Cualquier otro valor produce 422
fechaRequerida	string fecha y hora RFC 3339 en UTC, como en el anexo fixture-scenarios.json (supuesto CL-02)	Obligatoria Formato inválido produce 422 Al enviar no puede ser anterior al instante de envío del servidor; igual o posterior se acepta
observaciones	string opcional, texto plano	Máximo 1000 caracteres (supuesto CL-03) Se trata como dato no confiable y se escapa al mostrarse
lineas	array de objetos con sku y cantidad	Entre 1 y 10 elementos Sin SKU repetidos
lineas.sku	string	SKU activo del inventario de la organización autenticada Repetido, inactivo, inexistente o de otra organización produce 422

Entrada	Tipo	Validación
lineas.cantidad	integer	Entero entre 1 y 500 inclusive Cero, negativo, decimal, texto o ausente produce 422
codigo, solicitante, organizationId, estado	generados por el servidor	Si el cliente los envía la petición se rechaza con 422 y nunca se reasignan

Proceso

• Autenticar y autorizar según SPEC-01: solo el rol Solicitante crea borradores

• Validar esquema y reglas RF03 de cabecera y líneas; si falla responder 422 con el error asociado a cada campo, sin persistir nada

• Persistir cabecera y líneas en una transacción como BORRADOR con código único generado, solicitante y organización tomados de la identidad

• Editar: comprobar dueño y estado BORRADOR, revalidar y reemplazar cabecera y líneas de forma atómica

• Enviar: en una transacción bloquear la solicitud, comprobar dueño y estado BORRADOR, revalidar RF03 incluida fechaRequerida contra el instante de envío, cambiar a ENVIADA y registrar el evento de auditoría

• Responder con el estado confirmado; enviar no modifica el inventario

Reglas de negocio

• RF03: la solicitud contiene código generado, solicitante, organización, zona, prioridad NORMAL o ALTA, fecha requerida, observaciones opcionales y de 1 a 10 líneas distintas

• Cada línea usa un SKU activo y una cantidad entera de 1 a 500; no se aceptan SKU repetidos, negativos, decimales ni una fecha anterior al momento de envío

• Solo el borrador es editable y solo su dueño lo edita y lo envía

• Enviar no reserva inventario; la reserva pertenece a SPEC-03

• La validación ocurre en el servidor aunque la interfaz también valide

• El envío exitoso registra un evento de auditoría con los campos de RF09 en la misma transacción

Casos límite

• 0, 1, 10 y 11 líneas

• Cantidades 0, 1, 500, 501, -1, 2.5, el texto 5 y cantidad ausente

• SKU repetido, inactivo, inexistente y de ORG-B

• Zona desconocida y prioridad MEDIA

• fechaRequerida con formato inválido, anterior, igual y posterior al instante de envío

• Observaciones de 1000 y 1001 caracteres

• Cuerpo con codigo, organizationId, estado o solicitante

• Doble envío de la misma solicitud

Supuestos registrados

• Los borradores se validan al crear, al editar y de nuevo al enviar

• Formato de fecha y zona horaria de visualización (America/Bogota) según CL-02, decisión del equipo

• Límite de observaciones de 1000 caracteres según CL-03, decisión del equipo

• Formato del código generado según CL-10, decisión del equipo

Preguntas registradas

• CL-01: catálogo definitivo de zonas y tratamiento de zona desconocida (decisión del equipo)

• CL-02: formato de fecha y visualización horaria (decisión del equipo)

Dependencias

• SPEC-01: identidad y permisos

• Catálogo de SKU activos por organización sembrado (anexo fixture-scenarios.json)

• SPEC-04: estructura del evento de auditoría

Salidas

Condición	Resultado
Creación válida	201 con id, código, estado BORRADOR y líneas persistidas; inventario sin cambios
Edición válida del borrador propio	200 con el borrador actualizado
Envío válido	200 con estado ENVIADA; un evento de auditoría; existencia física y reservada sin cambios
Datos inválidos	422 con el campo inválido; ninguna cabecera, línea ni evento persistido
Edición o envío por un rol distinto de Solicitante o por otro solicitante de su organización	403 sin cambios
Solicitud inexistente o de otra organización	404
Edición o envío fuera de BORRADOR	409 sin cambios

Criterios de aceptación

AC-02-01 · positivo · RF03

Dado: un solicitante de ORG-A autenticado y los SKU KIT-ALIMENTO y KIT-AGUA activos

Cuando: crea un borrador con zona NORTE, prioridad ALTA, fechaRequerida futura y dos líneas distintas con cantidades válidas

Entonces: recibe 201; la base contiene la cabecera en BORRADOR y ambas líneas; el inventario no cambia

AC-02-02 · negativo · RF03, RNF01

Dado: un solicitante de ORG-A autenticado y un SKU activo

Cuando: crea, edita o envía una solicitud cuya línea tiene cantidad 0

Entonces: recibe 422 con un error asociado a la cantidad; el borrador conserva su estado previo, no existe una solicitud ENVIADA nueva y el inventario y la auditoría de transiciones no cambian

AC-02-03 · negativo · RF04

Dado: una solicitud propia en ENVIADA

Cuando: el solicitante dueño intenta editarla

Entonces: recibe 409; cabecera, líneas y estado no cambian

AC-02-04 · limite · RF03

Dado: un borrador válido, el reloj de prueba en 2030-01-10T14:00:00Z y fechaRequerida 2030-01-10T13:59:59Z

Cuando: el dueño lo envía

Entonces: recibe 422 asociado a fechaRequerida; la solicitud sigue en BORRADOR y no se registra evento

AC-02-05 · positivo · RF03

Dado: un solicitante de ORG-A autenticado

Cuando: crea dos borradores válidos

Entonces: cada uno recibe un código distinto generado por el sistema; solicitante es la cuenta autenticada y organización es ORG-A en ambos

AC-02-06 · negativo · RF03, RNF01

Dado: un solicitante de ORG-A autenticado

Cuando: crea o envía con 0 u 11 líneas, SKU repetido, inactivo, inexistente o de ORG-B, cantidad -1, 501, 2.5 o texto, zona desconocida, prioridad MEDIA, observaciones de 1001 caracteres, o incluye codigo, organizationId, estado o solicitante en el cuerpo

Entonces: cada caso recibe 422 con el campo inválido; no quedan cabeceras ni líneas parciales, no hay evento de éxito y el inventario no cambia

AC-02-07 · limite · RF03, RNF01

Dado: un solicitante de ORG-A autenticado

Cuando: crea borradores con 1 línea y con 10 líneas distintas, cantidades 1 y 500 y observaciones vacías y de 1000 caracteres

Entonces: todos se aceptan con 201 y se persisten completos

AC-02-08 · positivo · RF04, RF09

Dado: un borrador válido propio con fechaRequerida igual o posterior al instante de envío

Cuando: el dueño lo envía

Entonces: recibe 200; la solicitud queda en ENVIADA con exactamente un evento de envío que registra identidad, organización, recurso, acción, fecha UTC y correlationId; existencia física y reservada no cambian

AC-02-09 · permiso · RF04

Dado: un borrador del solicitante de ORG-A

Cuando: el coordinador, la bodega o el auditor de ORG-A intentan editarlo o enviarlo

Entonces: cada intento recibe 403; cabecera, líneas y estado se conservan

AC-02-10 · negativo · RF04

Dado: solicitudes propias en ENVIADA, RESERVADA y DESPACHADA

Cuando: el dueño reenvía la ENVIADA o intenta editar las demás

Entonces: cada intento recibe 409, sin segundo evento de envío ni cambios de datos o inventario

AC-02-11 · positivo · RNF05

Dado: el formulario de creación y edición a 390 y 1366 px de ancho

Cuando: se completa y envía solo con teclado, provocando también un error de validación

Entonces: no hay desbordamiento horizontal; cada campo tiene etiqueta; los errores quedan asociados a su campo y el foco es visible; la verificación manual se registra sin afirmar conformidad WCAG total

Fuente: specs/SPEC-02.md

SPEC-03 · Inventario y transiciones

Versión: 0.4-draft. Estado: Borrador cotejado con el enunciado oficial; pendiente de revisión humana independiente

HU-03 — Como coordinador, encargado de bodega o solicitante dueño de una organización, quiero reservar, despachar, registrar la entrega y cancelar solicitudes mediante transiciones controladas, para el inventario nunca quede negativo ni se prometa dos veces la misma existencia.

Transiciones ENVIADA a RESERVADA a DESPACHADA a ENTREGADA y cancelación desde ENVIADA o RESERVADA, con inventario por organización y SKU, reserva atómica de todas las líneas, idempotencia con Idempotency-Key y auditoría confirmada en la misma transacción. Enunciado §3.

Requisitos relacionados: RF02, RF04, RF05, RF06, RF07, RF09, RNF02, RNF05.

Actores

• Coordinador: reserva ENVIADA y registra ENTREGADA sobre DESPACHADA

• Bodega: despacha RESERVADA

• Solicitante dueño: cancela sus solicitudes en ENVIADA o RESERVADA

• Auditor: sin permiso de transición

Alcance

• Reserva total o nula con Idempotency-Key y control de concurrencia

• Despacho, entrega y cancelación con sus efectos exactos sobre el inventario

• Rechazo 409 de toda transición no indicada, sin efectos

• Evento de auditoría y resultado idempotente confirmados junto con estado e inventario

Fuera del alcance

• Ajustes manuales de existencia física: no hay API de ajuste; el stock inicial proviene del seed (CL-06)

• Devoluciones, rutas y GPS (fuera del alcance, enunciado §1)

• Idempotencia de operaciones distintas de la reserva (no exigida; CL-11)

Entradas y validaciones

Entrada	Tipo	Validación
requestId	string en la ruta	Debe existir en la organización autenticada; si no, 404
operación	enum RESERVAR, DESPACHAR, ENTREGAR o CANCELAR (una ruta por operación según el contrato G2)	Determina el rol permitido y el estado de origen Rol no permitido sobre recurso de su organización produce 403
Idempotency-Key	encabezado string de 1 a 128 caracteres imprimibles (supuesto CL-11)	Obligatorio en RESERVAR; ausente o inválido produce 422 sin escritura (supuesto) Se procesa solo después de autenticar y autorizar
cuerpo de la reserva	objeto JSON según el contrato G2; puede ser vacío	Su forma canónica junto con requestId forma la huella de contenido de la clave
inventario por SKU	onHand entero no negativo, reserved entero no negativo; disponible derivado igual a onHand menos reserved	reserved nunca supera onHand Pertenece a una sola organización

Proceso

• Autenticar; resolver la solicitud dentro de la organización (404 si no existe en ella); autorizar el rol para la operación (403 si no)

• RESERVAR: tras autorizar, buscar la clave en el ámbito clave, usuario, organización y operación; si existe con la misma huella devolver el código y cuerpo almacenados sin nuevos efectos; si la huella difiere responder 409

• Abrir transacción; bloquear la solicitud y las filas de inventario de sus SKU en orden estable por SKU

• Verificar el estado de origen; si la transición no está indicada en RF04 responder 409 sin cambios

• RESERVAR desde ENVIADA: comprobar disponible mayor o igual que la cantidad en todas las líneas; si alguna falla responder 409 y revertir todo; si todas cumplen, aumentar reserved de cada línea y pasar a RESERVADA

• DESPACHAR desde RESERVADA: disminuir onHand y reserved en las cantidades de la solicitud y pasar a DESPACHADA

• ENTREGAR desde DESPACHADA: pasar a ENTREGADA sin tocar el inventario

• CANCELAR desde ENVIADA o RESERVADA por el solicitante dueño: si estaba RESERVADA disminuir reserved exactamente en sus cantidades sin tocar onHand; pasar a CANCELADA

• Registrar el evento de auditoría y, en la reserva, el resultado idempotente dentro de la misma transacción; confirmar; cualquier fallo antes del commit revierte todo

• Responder con el estado y las cantidades confirmados

Reglas de negocio

• RF04: flujo base BORRADOR, ENVIADA, RESERVADA, DESPACHADA, ENTREGADA; ENVIADA y RESERVADA pueden pasar a CANCELADA por el solicitante dueño; toda transición no indicada se rechaza con 409 y conserva datos e inventario

• RF05: la reserva cubre todas las líneas o ninguna; solo desde ENVIADA; disponible igual a existencia física menos reservada; las tres cantidades no negativas

• RF06: cancelar una RESERVADA libera exactamente su reserva sin cambiar la existencia física; despachar disminuye física y reservada en las cantidades de la solicitud; ENTREGADA no altera inventario; cancelar una ENVIADA no altera inventario

• RF07: cada petición de reserva incluye Idempotency-Key; misma clave, usuario, organización, operación y contenido repiten el resultado sin duplicar efectos; misma clave con contenido diferente devuelve 409; el resultado se conserva al menos 24 horas

• La clave se procesa después de autenticar y autorizar y no permite recuperar la respuesta de otro usuario

• Dos peticiones simultáneas que compiten por existencias insuficientes no pueden producir dos reservas exitosas; un error antes del commit no deja reserva parcial

• Estado, inventario, evento de auditoría y resultado idempotente se confirman juntos

• Cada operación afecta solo el inventario de su organización

Casos límite

• Disponible exactamente igual a la cantidad pedida

• Una línea suficiente y otra insuficiente en la misma solicitud

• A-001 y A-002 reservadas a la vez, 7 unidades cada una de KIT-ALIMENTO con existencia física 10

• Doble despacho de la misma solicitud

• Entregar una RESERVADA; cancelar BORRADOR, DESPACHADA o ENTREGADA; cualquier salida de CANCELADA o ENTREGADA

• Repetición de clave a las 23 h 59 min y a las 24 h

• Misma clave textual usada por otro usuario u otra organización

• Reserva sin Idempotency-Key

• Fallo inducido antes del commit

• Rol incorrecto para cada operación

Supuestos registrados

• Retención de la clave exactamente 24 horas desde su creación; en ese instante deja de repetir (CL-11, decisión del equipo)

• Se almacenan las respuestas completadas de la reserva, incluido el 409 de negocio; no se almacenan 401, 403, 422 ni 500, que pueden reintentarse con la misma clave (CL-04; debe fijarse en el contrato G2)

• Clave ausente produce 422 (decisión del equipo)

• No existe API de ajuste de stock (CL-06)

Preguntas registradas

• CL-04 y CL-11: confirmar en el contrato OpenAPI la política de errores almacenados, reintentos y expiración

Dependencias

• SPEC-01: identidad y matriz de permisos

• SPEC-02: solicitudes en ENVIADA

• SPEC-04: estructura del evento de auditoría

• Base relacional con transacciones y bloqueo de filas (ADR de transacciones e idempotencia, G2)

Salidas

Condición	Resultado
Transición válida	200 con estado y cantidades confirmados; un evento de auditoría
Repetición con la misma clave y el mismo contenido dentro de la retención	El mismo código y cuerpo originales, sin nueva reserva ni nuevo evento
Misma clave con contenido distinto	409 sin efectos
Alguna línea sin disponibilidad suficiente	409; ninguna línea ni el estado cambian
Transición no indicada, incluida una segunda reserva con otra clave	409 conservando datos e inventario
Rol no autorizado para la operación sobre recurso de su organización	403 sin efectos y sin almacenar la clave
Solicitud de otra organización o inexistente	404 sin efectos

Criterios de aceptación

AC-03-01 · positivo · RF05, RNF02

Dado: el seed restablecido: KIT-ALIMENTO de ORG-A con físico 10 y reservado 0, A-001 ENVIADA con 7 unidades y el coordinador de ORG-A autenticado

Cuando: reserva A-001 con una Idempotency-Key nueva

Entonces: recibe 200; A-001 queda RESERVADA; KIT-ALIMENTO queda con físico 10, reservado 7 y disponible 3; hay un evento de reserva; el inventario de ORG-B no cambia

AC-03-02 · negativo · RF05, RNF02

Dado: una solicitud ENVIADA de ORG-A con una línea suficiente de 5 KIT-AGUA (físico 20) y otra insuficiente de 9 KIT-HIGIENE (físico 8)

Cuando: el coordinador la reserva

Entonces: recibe 409; el estado sigue ENVIADA; reservado de ambos SKU sin cambios; no hay evento de éxito ni resultado parcial

AC-03-03 · fallo · RF05, RF07, RNF02

Dado: dos solicitudes ENVIADA que compiten por existencias insuficientes del mismo SKU

Cuando: se reservan simultáneamente con claves distintas mediante una barrera de sincronización, repitiendo el escenario limpio al menos 20 veces

Entonces: en ninguna repetición se confirman ambas; reservado nunca supera físico y ninguna cantidad queda negativa

AC-03-04 · negativo · RF07, RNF02

Dado: A-001 reservada con la clave K1

Cuando: el mismo coordinador repite K1 con el mismo contenido y después repite K1 con otro requestId o cuerpo

Entonces: la repetición idéntica devuelve el mismo código y cuerpo, reservado sigue en 7 y hay un solo evento; la repetición con contenido distinto recibe 409 sin efectos

AC-03-05 · positivo · RF04, RF06, RNF02

Dado: A-001 RESERVADA con KIT-ALIMENTO en físico 10 y reservado 7, en dos escenarios limpios

Cuando: en el primero el solicitante dueño cancela; en el segundo la bodega despacha y luego el coordinador registra la entrega

Entonces: la cancelación deja CANCELADA con físico 10, reservado 0 y disponible 10; el despacho deja DESPACHADA con físico 3, reservado 0 y disponible 3; la entrega deja ENTREGADA con las mismas cantidades; un evento por transición

AC-03-06 · negativo · RF04, RF06

Dado: A-002 ENVIADA

Cuando: el solicitante dueño la cancela y luego repite la cancelación

Entonces: la primera deja CANCELADA con un evento y sin cambios de físico o reservado; la segunda recibe 409 sin efectos

AC-03-07 · negativo · RF04, RNF02

Dado: solicitudes en cada estado del flujo

Cuando: se intenta cada transición no indicada en RF04: reservar BORRADOR o RESERVADA, despachar ENVIADA, entregar RESERVADA, cancelar BORRADOR, DESPACHADA o ENTREGADA y cualquier transición desde CANCELADA o ENTREGADA

Entonces: cada intento recibe 409; los snapshots de solicitud, líneas, inventario y auditoría de éxito son idénticos antes y después

AC-03-08 · fallo · RF05, RF07, RNF02

Dado: el seed restablecido con KIT-ALIMENTO de ORG-A en físico 10 y A-001 y A-002 ENVIADA con 7 unidades cada una

Cuando: se reservan simultáneamente con claves distintas

Entonces: una recibe 200 y la otra 409, sin fijar cuál; KIT-ALIMENTO queda con físico 10, reservado 7 y disponible 3; existe exactamente un evento de reserva

AC-03-09 · fallo · RF05, RF09, RNF02

Dado: A-001 ENVIADA y un fallo inducido al escribir el evento de auditoría antes del commit

Cuando: el coordinador reserva A-001

Entonces: recibe 500 con correlationId sanitizado; la transacción revierte estado, stock y auditoría; no se conserva resultado idempotente, permitiendo reintento con la misma clave

AC-03-10 · limite · RF07

Dado: una reserva exitosa con K1 creada en el instante t0 del reloj de prueba

Cuando: el mismo coordinador repite K1 con el mismo contenido en t0 más 23 h 59 min, y luego con otro requestId

Entonces: la repetición idéntica devuelve la respuesta original con un único evento; la variante con otro requestId recibe 409

AC-03-11 · limite · RF07

Dado: K1 creada en t0 para A-001, que ya está RESERVADA

Cuando: se reutiliza K1 en t0 más 24 h, con la retención vencida según el supuesto CL-11

Entonces: no hay repetición del resultado; la operación se reevalúa y recibe 409 porque A-001 ya no está ENVIADA; reservado no cambia

AC-03-12 · permiso · RF07, RF02

Dado: una reserva con K1 hecha por el coordinador de ORG-A

Cuando: el coordinador de ORG-B usa K1 para reservar B-001, y aparte llega una reserva sin Idempotency-Key

Entonces: K1 en ORG-B se trata como clave independiente y nunca devuelve la respuesta de ORG-A; la reserva sin clave recibe 422 sin escritura

AC-03-13 · negativo · RF04, RF06, RNF02

Dado: A-001 RESERVADA con KIT-ALIMENTO en físico 10 y reservado 7

Cuando: la bodega la despacha dos veces y después el coordinador registra la entrega

Entonces: el primer despacho recibe 200 y el segundo 409; físico y reservado disminuyen una sola vez hasta físico 3 y reservado 0; la entrega solo cambia el estado y añade un evento

AC-03-14 · negativo · RF07, RF04

Dado: A-001 RESERVADA mediante la clave K1

Cuando: el coordinador intenta reservar A-001 con otra clave K2

Entonces: recibe 409 porque el estado ya no es ENVIADA; reservado sigue en 7 y K2 no produce efectos

AC-03-15 · permiso · RF02, RF04, RF07

Dado: A-001 en ENVIADA, RESERVADA o DESPACHADA según el caso, en escenarios limpios de ORG-A

Cuando: la bodega o el solicitante intentan reservar, el coordinador o el auditor intentan despachar, la bodega intenta registrar la entrega y el coordinador intenta cancelar

Entonces: cada intento recibe 403 sin cambios de estado, inventario ni auditoría; la Idempotency-Key enviada en un intento no autorizado no se almacena ni permite recuperar respuestas

AC-03-16 · positivo · RNF05

Dado: las pantallas con las acciones reservar, despachar, entregar y cancelar a 390 y 1366 px de ancho

Cuando: cada rol ejecuta su acción solo con teclado, provocando también un rechazo 409

Entonces: no hay desbordamiento horizontal; los controles tienen nombre visible; el rechazo se muestra asociado a la acción; la verificación manual se registra sin afirmar conformidad WCAG total

AC-03-17 · fallo · RF04, RF06, RNF02, RF09

Dado: A-001 RESERVADA, físico 10/reservado 7/disponible 3, dos procesos PostgreSQL reales y barrera

Cuando: Bodega despacha y Solicitante dueño cancela simultáneamente la misma solicitud

Entonces: una petición recibe 200 y la otra 409; si gana despacho queda DESPACHADA con 3/0/3, si gana cancelación queda CANCELADA con 10/0/10; exactamente un evento exitoso nuevo, sin efectos parciales

Fuente: specs/SPEC-03.md

SPEC-04 · Consultas y auditoría

Versión: 0.3.2-draft. Estado: Borrador cotejado con el enunciado oficial; pendiente de revisión humana independiente

HU-04 — Como solicitante, coordinador, encargado de bodega o auditor de una organización, quiero consultar solicitudes, tablero, inventario e historial de auditoría dentro de mi alcance, para pueda dar seguimiento y demostrar quién realizó cada operación sin ver datos de otra organización.

Listados paginados con filtros, tablero de cantidades por estado e inventario, historial de auditoría inmutable vía API y condiciones operativas de consulta: rendimiento, arranque reproducible, logs con correlationId y health y readiness. Enunciado §4 y §5.

Requisitos relacionados: RF02, RF08, RF09, RNF03, RNF04, RNF05, RNF06.

Actores

• Solicitante: solo sus solicitudes

• Coordinador: solicitudes, inventario e historial de su organización (CL-16/17 reportadas); Bodega: solicitudes e inventario sin auditoría

• Auditor: solicitudes, inventario y auditoría de su organización

• Operador o evaluador: arranque, health y readiness

Alcance

• Listados paginados con máximo 100 elementos y filtros por estado, prioridad y zona

• Tablero con cantidades por estado y cantidades físicas, reservadas y disponibles

• Escritura y consulta del historial de auditoría sin edición ni borrado por API

• Logs estructurados con correlationId, health y readiness diferenciados

• Rendimiento de listados y tablero y arranque desde clon limpio

Fuera del alcance

• Exportaciones, reportes adicionales y búsqueda de texto libre (no exigidos)

• Rendimiento del asistente de IA (excluido de RNF03)

Entradas y validaciones

Entrada	Tipo	Validación
page	integer	Mayor o igual que 1; valor por defecto 1 Inválido produce 422
pageSize	integer	Entre 1 y 100; valor por defecto 20 (supuesto) 0, 101 o no entero produce 422
estado	enum BORRADOR, ENVIADA, RESERVADA, DESPACHADA, ENTREGADA o CANCELADA; opcional	Otro valor produce 422
prioridad	enum NORMAL o ALTA; opcional	Otro valor produce 422
zona	string del catálogo de CL-01; opcional	Zona desconocida produce 422 (supuesto)

Entrada	Tipo	Validación
requestId del historial	string	Debe existir en la organización autenticada; si no, 404
X-Correlation-Id	encabezado string opcional (supuesto: UUID)	Si falta o es inválido el servidor genera uno Nunca se registra sin sanitizar

Proceso

• Autenticar y determinar el alcance: Solicitante, solo sus solicitudes; Coordinador, Bodega y Auditor, su organización según la matriz de SPEC-01

• Aplicar el alcance antes de filtros, conteos y paginación; ordenar de forma estable por fecha de creación e identificador

• Tablero: contar solicitudes por estado y calcular físico, reservado y disponible por SKU con el mismo alcance

• Auditoría: los módulos de SPEC-02, SPEC-03 y SPEC-05 escriben el evento en la misma transacción del cambio con identidad, organización, recurso, acción, fecha UTC y correlationId; la consulta devuelve eventos en orden temporal

• Registrar logs técnicos estructurados con correlationId para cada petición, incluidos los rechazos, sin secretos

• Health responde si el proceso está vivo; readiness comprueba la base de datos y las migraciones aplicadas; el proveedor de IA no forma parte de readiness

Reglas de negocio

• RF08: listados paginados con máximo 100 elementos por página, filtros por estado, prioridad y zona y tablero con cantidades por estado; el solicitante ve solo sus solicitudes

• El tablero permite observar solicitudes por estado y cantidades disponibles y reservadas (objetivos del cliente, §1)

• RF09: se registra cada transición exitosa y cada aprobación de resumen con identidad, organización, recurso, acción, fecha UTC y correlationId; no hay edición ni borrado por API; un rechazo solo genera log técnico

• RF02: listados, auditoría y consultas agregadas respetan el límite de organización

• RNF03: p95 menor o igual a 700 ms y errores menores al 1 % con 20 usuarios virtuales durante 60 s tras 5 s de calentamiento, sobre 2.000 solicitudes sembradas, sin IA; reportar hardware y herramienta

• RNF04: iniciar desde un clon limpio en 15 min o menos con versiones fijadas, migraciones, seed y un comando documentado; la descarga inicial se reporta aparte

• RNF06: logs estructurados con correlationId sin secretos; health y readiness diferenciados

• El seed pequeño y el seed de carga de 2.000 solicitudes son independientes (enunciado §12)

Casos límite

• Página fuera de rango y filtros combinados sin coincidencias

• pageSize 0, 1, 100 y 101

• Empates de fecha de creación en la ordenación

• correlationId malicioso o excesivamente largo

• Solicitante sin solicitudes

• Auditor de ORG-A con el identificador de un evento o solicitud de ORG-B

• Base detenida durante la comprobación de readiness

Supuestos registrados

• pageSize por defecto 20 y orden por fecha de creación e identificador (decisión del equipo)

• Formato UUID para correlationId (decisión del equipo)

• RNF03, RNF04 y health y readiness se ubican en esta SPEC porque cubren consultas y operación; ninguna otra SPEC trata la operación

Preguntas registradas

• CL-16: respuesta afirmativa docente reportada por el coordinador; evidencia original pendiente

• CL-17: Coordinador consulta historial de su organización y Solicitante de sus solicitudes según respuesta reportada; evidencia original pendiente

• CL-18: tablero propio sin inventario para Solicitante según respuesta reportada; evidencia original pendiente

• CL-15: retención de auditoría y de logs técnicos (equipo)

Dependencias

• SPEC-01: alcance por rol y organización

• SPEC-02, SPEC-03 y SPEC-05: producen los eventos de auditoría

• Seed de carga con 2.000 solicitudes y herramienta de carga k6 o equivalente

Salidas

Condición	Resultado
Listado válido	200 con items, page, pageSize y total del alcance; una página fuera de rango devuelve items vacío
Tablero	200 con conteos por estado y cantidades de inventario según el rol
Historial de una solicitud	200 con los eventos en orden temporal
Parámetros inválidos	422
Sin identidad, rol no permitido o recurso ajeno	401, 403 o 404 según SPEC-01; nunca conteos de otra organización
Health y readiness	Health 200 si el proceso vive; readiness 200 solo con base disponible y migraciones aplicadas, 503 en otro caso

Criterios de aceptación

AC-04-01 · permiso · RF08, RF02

Dado: un solicitante de ORG-A con solicitudes propias y existen solicitudes de otro solicitante de ORG-A y de ORG-B

Cuando: lista solicitudes

Entonces: solo recibe las propias; total cuenta solo las propias; pageSize nunca supera 100

AC-04-02 · permiso · RF08, RF02

Dado: solicitudes de ORG-A y ORG-B en varios estados

Cuando: el coordinador, la bodega y el auditor de ORG-A filtran por estado, prioridad y zona y consultan el tablero

Entonces: resultados y conteos incluyen solo solicitudes de ORG-A

AC-04-03 · positivo · RF09

Dado: una transición exitosa de cada tipo (envío, reserva, despacho, entrega y cancelación) y una aprobación de resumen

Cuando: cada operación se confirma

Entonces: existe exactamente un evento por operación con identidad, organización, recurso, acción, fecha UTC y correlationId, confirmado en la misma transacción que el cambio de estado o inventario

AC-04-04 · negativo · RF09

Dado: el contrato OpenAPI publicado y una operación rechazada con 409, 403 o 422

Cuando: se revisan las rutas y se consulta la auditoría después del rechazo

Entonces: no existe ruta que edite o borre auditoría; el rechazo deja como máximo un log técnico y ningún evento de transición exitosa

AC-04-05 · límite · RF08

Dado: un usuario autorizado

Cuando: pide pageSize 0, 101 o no entero, page 0 o un estado desconocido, y después una página fuera de rango

Entonces: los parámetros inválidos reciben 422; la página fuera de rango recibe 200 con items vacío y sin datos ajenos

AC-04-06 · positivo · RF08

Dado: datos conocidos de ORG-A sembrados para la prueba

Cuando: un usuario de la organización combina filtros de estado, prioridad y zona

Entonces: items contiene solo las coincidencias autorizadas; total y tablero coinciden con una consulta directa a la base con el mismo alcance, calculada de forma independiente

AC-04-07 · positivo · RF09, RNF06

Dado: una transición enviada con un X-Correlation-Id válido

Cuando: se completa

Entonces: el mismo correlationId aparece en la respuesta, en el log estructurado y en el evento; actor y organización son correctos y la fecha está en UTC

AC-04-08 · negativo · RF09

Dado: eventos de auditoría existentes

Cuando: se envían PUT, PATCH y DELETE a las rutas de auditoría

Entonces: reciben 404 o 405 y el contenido de la auditoría es idéntico antes y después

AC-04-09 · positivo · RNF03

Dado: el seed de carga con 2.000 solicitudes y la IA excluida

Cuando: k6 o una herramienta equivalente ejecuta 20 usuarios virtuales sobre listados y tablero, descarta 5 s de calentamiento y mide 60 s

Entonces: p95 es menor o igual a 700 ms por endpoint y la tasa de errores menor al 1 %; se conservan la salida real, el hardware, la herramienta y su versión

AC-04-10 · permiso · RF08, RF02

Dado: inventario sembrado de ORG-A y ORG-B

Cuando: bodega, auditor y coordinador de ORG-A consultan inventario, y el solicitante de ORG-A intenta consultarlo y consulta su tablero

Entonces: bodega, auditor y coordinador ven físico, reservado y disponible consistentes solo de ORG-A; disponible igual a físico menos reservado; el solicitante recibe 403 en inventario y su tablero muestra solo conteos de solicitudes propias, sin inventario ni conteos ajenos (CL-16/18 reportadas)

AC-04-11 · permiso · RF09, RF02

Dado: eventos de auditoría de ORG-A y de ORG-B

Cuando: auditor y coordinador de ORG-A consultan historial; solicitante consulta historial propio y ajeno; bodega consulta historial; todos intentan acceder al historial de una solicitud de ORG-B

Entonces: auditor y coordinador ven solo eventos de ORG-A; solicitante solo eventos de sus solicitudes y obtiene 403 para una solicitud de otro dueño de ORG-A; bodega recibe 403 para recurso de ORG-A; identificadores inexistentes o de ORG-B reciben 404 sin datos (CL-17 y semántica oficial del apartado 2)

AC-04-12 · positivo · RNF04

Dado: un clon limpio del commit evaluado con versiones fijadas y configuración de ejemplo sin secretos

Cuando: se ejecuta el comando único documentado en el runbook

Entonces: las migraciones y el seed pequeño quedan aplicados y la aplicación responde en 15 min o menos medidos sin contar la descarga inicial, que se reporta aparte; se conservan tiempos, comando y entorno

AC-04-13 · fallo · RNF06

Dado: la aplicación levantada

Cuando: se consultan health y readiness con la base disponible y luego con la base detenida

Entonces: health responde 200 en ambos casos; readiness responde 200 con base disponible y 503 sin base; el estado del proveedor de IA no afecta readiness

AC-04-14 · positivo · RNF05

Dado: listados, filtros, tablero e historial a 390 y 1366 px de ancho

Cuando: se navegan y filtran solo con teclado, provocando también un filtro inválido

Entonces: no hay desbordamiento horizontal; los controles tienen etiqueta; el error queda asociado al filtro; la verificación manual se registra sin afirmar conformidad WCAG total

Fuente: specs/SPEC-04.md

SPEC-05 · Asistente IA

Versión: 0.4-draft. Estado: Borrador cotejado con el enunciado oficial; pendiente de revisión humana independiente

HU-05 — Como coordinador de una organización, quiero seleccionar hasta 20 solicitudes ENVIADA de mi organización y obtener un resumen con recomendaciones validadas que pueda aprobar, para oriente mi revisión sin que el modelo decida, cambie prioridades ni mueva inventario.

Resumen asistido por IA de hasta 20 solicitudes ENVIADA elegidas por el coordinador, con proyección de campos autorizados, adaptador de proveedor intercambiable, validación estructural y de pertenencia, degradación determinista y aprobación humana auditada. Enunciado §4 y §10.

Requisitos relacionados: RF02, RF09, RF10, RF11, RF12, RNF01, RNF06.

Actores

• Coordinador: solicita y aprueba resúmenes de su organización

• Proveedor de IA: externo y no confiable; real, local, reproducción declarada o fixture

• Sistema: adaptador, validador y generador del resumen alternativo

• Auditor, Bodega y Solicitante: sin acceso al asistente

Alcance

• Selección por identificador de 1 a 20 solicitudes ENVIADA de la organización

• Proyección de los seis campos autorizados por RF10

• Adaptador intercambiable con plazo de 5 s

• Validación contra ai-output.schema.json y de pertenencia de identificadores

• Resumen determinista alternativo ante salida inválida, timeout o fallo

• Borrador identificado como asistencia de IA y aprobación auditada

Fuera del alcance

• Ejecutar acciones sugeridas por el modelo o cambiar prioridad, reserva o despacho desde el asistente

• Exigir al modelo explicar su razonamiento interno o usar su confianza declarada como evidencia

• Uso de más modelos o proveedores de pago (opcional, sin puntos extra)

Entradas y validaciones

Entrada	Tipo	Validación
requestIds	array de string	Entre 1 y 20 identificadores únicos; vacío, más de 20 o repetidos produce 422 sin llamar al proveedor Cada uno debe ser de la organización del coordinador; si no, 404 Cada uno debe estar en ENVIADA; si no, 409 (supuesto CL-19)
payload al adaptador	lista de objetos con requestId, zona, prioridad, fechaRequerida, estado y observaciones	Solo esos seis campos (RF10) Nunca contraseñas, sesiones, nombre del solicitante, líneas ni datos de otra organización Observaciones delimitadas como dato no confiable

Entrada	Tipo	Validación
salida del proveedor	texto que debe contener un objeto JSON	Conforme a ai-output.schema.json: sin propiedades adicionales en ningún nivel, summary de 1 a 600 caracteres, recommendations de 0 a 5 Cada recomendación con requestId del conjunto enviado, reason de 1 a 240 caracteres y evidenceFields de 1 a 3 claves únicas entre zona, prioridad, fechaRequerida y observaciones requestId sin duplicados entre recomendaciones
summaryId para aprobar	string	Borrador de la organización del coordinador; si no, 404

Proceso

• Autenticar; solo el Coordinador puede solicitar o aprobar; Auditor, Bodega y Solicitante reciben 403

• Validar la selección y resolver cada identificador en la organización y en estado ENVIADA

• Proyectar solo los seis campos autorizados y marcar las observaciones como dato no confiable

• Invocar el adaptador con un plazo de 5 s; el modelo no recibe herramientas, credenciales ni acceso a la base

• Validar la respuesta contra el esquema y comprobar en código que cada requestId pertenece al conjunto enviado y no se repite

• Si es válida, guardar el borrador con su origen (proveedor y modelo, reproducción declarada o fixture) y la etiqueta de asistencia de IA

• Si la salida es inválida, vence el plazo o falla el proveedor, devolver un mensaje controlado y un resumen determinista alternativo con origen fallback; el resto del sistema sigue funcionando

• Mostrar summary y reason como texto escapado; nunca ejecutar marcado ni instrucciones

• Aprobar: registrar aprobación y evento de auditoría en una transacción sin cambiar prioridad, inventario ni estado

Reglas de negocio

• RF10: el coordinador solicita un resumen de hasta 20 solicitudes ENVIADA de su organización seleccionadas por identificador; el adaptador recibe solo requestId, zona, prioridad, fecha requerida, estado y observaciones

• RF11: summary hasta 600 caracteres; hasta cinco recomendaciones con requestId válido del conjunto recibido, reason hasta 240 caracteres y de una a tres evidenceFields permitidas; sin IDs duplicados o ajenos ni propiedades adicionales; el texto es contenido no confiable y nunca se ejecuta

• RF12: el resumen es un borrador identificable como asistencia de IA; solo el coordinador lo aprueba y deja constancia; aprobar no reserva, despacha ni cambia prioridad; salida inválida, timeout de 5 s o fallo del proveedor devuelven mensaje controlado y resumen determinista alternativo

• La prioridad proviene de la solicitud, no del modelo; la validación de pertenencia, estado y formato se hace en código, un prompt restrictivo no basta

• Interfaz de proveedor intercambiable; CI usa los fixtures deterministas del anexo sin servicios de pago

• Debe demostrarse una salida de un LLM real por API, modelo local o reproducción declarada con entrada, salida y origen, pasando por el mismo adaptador y validador; no se hardcodean recomendaciones ni se afirma una invocación en vivo que no ocurrió

• La aprobación se audita con los campos de RF09

• Decisiones propuestas G2: selección se valida formato 422 → pertenencia 404 → estado 409 antes de proveedor; fallback aprobable sin cambiar negocio; segunda aprobación 409. Timeout proveedor 5s, tolerancia de observación

fallback ≤250ms. Nueva revisión humana requerida.

Casos límite

• Selección de 0, 1, 20 y 21 identificadores

• Identificador repetido, B-001 de ORG-B y una solicitud RESERVADA

• JSON roto (fixture AI-JSON-BAD)

• summary vacío, de 600 y de 601 caracteres

• 0, 5 y 6 recomendaciones

• reason de 240 y 241 caracteres

• evidenceFields vacío, con 1, 3 y 4 claves, repetidas o con clave no permitida

• requestId duplicado o fuera del conjunto (fixture AI-FOREIGN-ID)

• Propiedad adicional execute (fixture AI-EXTRA)

• Marcado script en summary e instrucciones incrustadas en observaciones (fixture AI-INJECTION y untrusted-observation.txt)

• Respuesta a los 5001 ms (fixture AI-TIMEOUT), error del proveedor (AI-ERROR) y proveedor no configurado

Supuestos registrados

• El resumen alternativo es determinista para la misma selección y estado de datos y no incluye recomendaciones (CL-08, decisión del equipo)

• Se persisten borradores válidos y metadatos sanitizados de intentos fallidos, sin prompts con secretos (CL-05, decisión del equipo)

• Solicitud seleccionada fuera de ENVIADA produce 409 (CL-19, decisión del equipo)

Preguntas registradas

• CL-05: persistencia y retención de intentos de IA (equipo)

• CL-08: contenido exacto del resumen alternativo (equipo)

Dependencias

• SPEC-01: rol Coordinador y organización

• SPEC-02: solicitudes en ENVIADA

• SPEC-04: estructura del evento de auditoría

• Copia de trabajo de ai-output.schema.json en contracts/ (G2) y fixtures del anexo

Salidas

Condición	Resultado
Salida válida	200 con borrador identificado como asistencia de IA, summary, recommendations y origen
Salida inválida, timeout de 5 s o fallo del proveedor	200 con mensaje controlado, resumen determinista, recommendations vacío (CL-08) y origen fallback
Selección vacía, mayor de 20 o con repetidos	422 sin llamar al proveedor

Condición	Resultado
Identificador de otra organización o inexistente	404 sin llamar al proveedor
Solicitud seleccionada fuera de ENVIADA	409 sin llamar al proveedor (supuesto CL-19)
Rol distinto de Coordinador	403
Aprobación válida	200 con aprobador y fecha UTC; un evento de auditoría

Criterios de aceptación

AC-05-01 · positivo · RF10, RNF01

Dado: el coordinador de ORG-A autenticado y A-001 y A-002 en ENVIADA

Cuando: solicita un resumen seleccionando ambas

Entonces: el payload capturado en el adaptador contiene solo esas dos solicitudes y solo requestId, zona, prioridad, fechaRequerida, estado y observaciones

AC-05-02 · negativo · RF11, RNF01

Dado: los fixtures AI-FOREIGN-ID y AI-EXTRA y una salida con requestId repetido

Cuando: el adaptador devuelve cada una

Entonces: se rechazan; se muestran mensaje controlado y resumen alternativo; no aparece ningún dato de ORG-B y nada se ejecuta

AC-05-03 · fallo · RF12, RNF06

Dado: los fixtures AI-TIMEOUT con 5001 ms y AI-ERROR

Cuando: el coordinador solicita un resumen

Entonces: el adaptador corta la espera del proveedor a los 5 segundos; test instrumental permite hasta 250 ms adicionales de procesamiento del fallback (no ampliar timeout del proveedor); mensaje controlado y fallback determinista; listar/reservar/despachar siguen funcionando

AC-05-04 · positivo · RF12

Dado: un borrador válido de ORG-A

Cuando: el coordinador de ORG-A lo aprueba

Entonces: el borrador queda aprobado; prioridades, estados e inventario son idénticos antes y después según snapshot

AC-05-05 · limite · RF10, RF02, RNF01

Dado: el coordinador de ORG-A autenticado

Cuando: selecciona 21 identificadores, una lista vacía, identificadores repetidos, B-001 de ORG-B o una solicitud RESERVADA, y después 20 identificadores válidos

Entonces: los tres primeros casos reciben 422, B-001 recibe 404 y la RESERVADA 409, sin invocar al proveedor; con 20 válidos el proveedor se invoca una sola vez

AC-05-06 · negativo · RF11

Dado: salidas con summary vacío o de 601 caracteres, seis recomendaciones, reason de 241, evidenceFields vacío, con cuatro claves, repetidas o con clave no permitida, y el fixture AI-JSON-BAD

Cuando: se validan

Entonces: cada una se rechaza con motivo sanitizado y se usa el resumen alternativo; ninguna se guarda como borrador válido

AC-05-07 · limite · RF11

Dado: el fixture AI-VALID y salidas con summary de 600 caracteres, cinco recomendaciones con identificadores únicos del conjunto, reason de 240 y evidenceFields de una y de tres claves permitidas

Cuando: se validan

Entonces: se aceptan y se muestran como borrador de asistencia de IA

AC-05-08 · fallo · RF11, RNF01

Dado: una solicitud de ORG-A cuyas observaciones contienen el texto de untrusted-observation.txt y el fixture AI-INJECTION

Cuando: el coordinador solicita el resumen

Entonces: la instrucción incrustada no se obedece; el ID ajeno invalida la salida completa y se usa fallback; el texto malicioso rechazado no llega a pantalla; stock, estados, prioridades y permisos no cambian. Escape de salida válida se verifica por separado en AC-05-17

AC-05-09 · fallo · RF12, RNF06

Dado: el proveedor no configurado

Cuando: el coordinador solicita dos veces el resumen de la misma selección sin cambios en los datos

Entonces: ambas respuestas incluyen mensaje controlado y el mismo resumen determinista; no se requiere ningún servicio de pago

AC-05-10 · positivo · RF12

Dado: una salida válida del adaptador

Cuando: se muestra al coordinador

Entonces: aparece identificada como asistencia de IA con su origen; la prioridad mostrada es la de cada solicitud y ninguna recomendación se aplica sin una operación normal posterior

AC-05-11 · permiso · RF12, RF02

Dado: un borrador de ORG-A y otro de ORG-B

Cuando: el auditor, la bodega o el solicitante de ORG-A solicitan o aprueban un resumen, y el coordinador de ORG-A intenta aprobar el borrador de ORG-B

Entonces: los otros roles reciben 403; el borrador de ORG-B recibe 404; ningún borrador, stock ni prioridad cambia

AC-05-12 · positivo · RF09, RF12

Dado: un borrador válido de ORG-A

Cuando: el coordinador lo aprueba enviando un X-Correlation-Id

Entonces: se persiste junto a la aprobación un evento con identidad, organización, recurso, acción, fecha UTC y ese correlationId; las solicitudes y el inventario quedan idénticos

AC-05-13 · positivo · RF12

Dado: una respuesta real capturada de un LLM con su entrada, salida y origen declarados

Cuando: se ejecuta mediante el adaptador de reproducción

Entonces: pasa por el mismo adaptador y validador del producto; el origen se muestra como reproducción con su fixture y versión y no se reporta una invocación en vivo

AC-05-14 · positivo · RNF06

Dado: el pipeline de CI del repositorio

Cuando: ejecuta las pruebas del asistente

Entonces: usa solo los siete fixtures deterministas de ai-provider-fixtures.json, sin credenciales ni servicios de pago, y cada resultado coincide con el campo expected del fixture

AC-05-15 · positivo · RF12, RF09

Dado: borrador de ORG-A generado como fallback y coordinador autenticado con CSRF válido

Cuando: aprueba el borrador alternativo

Entonces: 200; conserva origen fallback y registra aprobación+evento en la misma transacción, sin cambios de solicitudes, prioridad o inventario

AC-05-16 · negativo · RF12, RF09

Dado: borrador ya APROBADO en ORG-A y su evento de aprobación existente

Cuando: el coordinador repite aprobación con CSRF válido

Entonces: 409; no cambia aprobación previa ni añade un segundo evento; solicitudes e inventario inalterados

AC-05-17 · positivo · RF11, RF12, RNF01

Dado: salida IA válida con IDs propios y texto <script>window.__unsafe=true</script> en summary, dentro de límites

Cuando: se valida y se muestra el borrador

Entonces: la salida válida se acepta, texto escapado visible, no se ejecuta script y window.__unsafe no se establece; sin cambios de inventario, estado o prioridad

Fuente: specs/SPEC-05.md

3. Arquitectura, datos y contratos

3.1 Estructura y límites

La propuesta es un monolito modular Laravel con PostgreSQL y una interfaz Blade/JavaScript del mismo origen. El servidor resuelve usuario, rol y organización; la interfaz solo presenta acciones permitidas. Estado, stock, auditoría y resultado idempotente se confirman en una transacción de negocio. La aprobación del resumen IA no reserva ni despacha kits.

Módulo	Responsabilidad	Límite relevante
Identity	Autenticación y sesión	Rol/organización proceden del servidor
Requests	Cabeceras y líneas, edición de borradores	Dueño y organización verificables
Inventory	Reserva, despacho, cancelación y entrega	Bloqueos, invariantes y transacción
Queries / Audit	Consultas y eventos	Alcance propio u organizacional según rol
AI	Resumen alternativo y aprobación	Sin escritura privilegiada de stock; proveedor real pendiente

Diferencia de implementación que requiere revisión: ADR-001 propone capas internas y routes/api.php; la versión provisional utiliza clases por módulo y rutas en routes/web.php para sesiones y CSRF. No se presenta esta diferencia como una nueva decisión del cliente ni como conformidad completa con el ADR.

3.2 Diagramas y modelo de datos

Artefacto	Qué documenta
contexto.md	Actores, sistema y servicios externos
componentes.md	Módulos y fronteras
datos.md	Entidades y relaciones
estados.md	Estados y transiciones permitidas
secuencia-reserva-concurrente.md	Competencia por existencias y resultado esperado
secuencia-ia-con-fallo.md	Validación, fallo del proveedor y fallback

Los seis diagramas editables Mermaid están versionados en docs/architecture/. Esta edición describe su contenido y enlaza sus fuentes; la incorporación de figuras renderizadas de los seis diagramas permanece pendiente para la revisión final.

Fuente: docs/architecture/componentes.md

Fuente: docs/architecture/contexto.md

Fuente: docs/architecture/datos.md

Fuente: docs/architecture/estados.md

Fuente: docs/architecture/secuencia-ia-con-fallo.md

Fuente: docs/architecture/secuencia-reserva-concurrente.md

Entidad	Datos principales	Control
organizations / users	Organización; usuario, rol y hash	Ocho cuentas ficticias iniciales
inventory_items	Organización + SKU; físico, reservado, activo	CHECK: 0 ≤ reservado ≤ físico
requests / request_lines	UUID, dueño, estado, fecha; SKU y cantidad	FK compuestas y cantidades positivas
audit_events	Actor, recurso, acción, UTC y correlationId	Eventos inmutables mediante trigger
idempotency_records	Usuario/org/operación/clave, hash, respuesta y TTL	Ámbito único; reserva ≥24 h
ai_summaries / ai_attempts	Resumen, origen, estado, aprobación e intento	Fallback identificado y aprobación separada

3.3 Contrato HTTP integrado

OpenAPI 3.1.1 integrado: 20 rutas y 22 operaciones. La siguiente tabla desarrolla la superficie HTTP; los esquemas y reglas completos se conservan en el contrato enlazado. El metadato introductorio del contrato aún contiene referencias históricas de G2; requiere alineación editorial, no una aprobación implícita.

Método	Ruta	Propósito
POST	/api/ai/summaries	Solicitar un resumen asistido por IA
POST	/api/ai/summaries/{summaryId}/approve	Aprobar un borrador de resumen
GET	/api/auth/csrf	Inicializar protección CSRF
POST	/api/auth/login	Iniciar sesión
POST	/api/auth/logout	Revocar sesión
GET	/api/auth/me	Consultar identidad del servidor
POST	/api/requests	Crear borrador propio
GET	/api/requests	Listar solicitudes paginadas
GET	/api/requests/{requestId}	Consultar solicitud
PATCH	/api/requests/{requestId}	Editar borrador propio
POST	/api/requests/{requestId}/send	send solicitud
POST	/api/requests/{requestId}/reserve	reserve solicitud
POST	/api/requests/{requestId}/dispatch	dispatch solicitud
POST	/api/requests/{requestId}/deliver	deliver solicitud
POST	/api/requests/{requestId}/cancel	cancel solicitud

Método	Ruta	Propósito
GET	/api/inventory	Consultar inventario
GET	/api/catalog	Consultar SKU activos para el formulario
GET	/api/dashboard	Consultar cantidades por estado
GET	/api/audit	Consultar auditoría inmutable
GET	/api/requests/{requestId}/audit	Consultar auditoría inmutable
GET	/health	Liveness del proceso
GET	/ready	Readiness de persistencia

Seguridad: cookie de sesión y CSRF en escrituras; 401 sin identidad, 403 cuando el rol o dueño carece de permiso y 404 para recurso inexistente o ajeno a la organización según el caso. La reserva exige Idempotency-Key. Los errores incluyen code, message y correlationId; validación puede añadir field. Solicitudes y listados se filtran en servidor antes de contar y paginar.

CL-16/17/18: se registra la confirmación afirmativa comunicada y la captura aportada por el coordinador; Coordinador consulta inventario/historial organizacional, Solicitante consulta historial y tablero propios. No se amplía acceso a datos ajenos. La evidencia debe conservarse con su procedencia real.

Fuente: contracts/openapi.yaml

Fuente: contracts/openapi-ia.yaml

Fuente: contracts/ai-output.schema.json

3.4 Decisiones de arquitectura

Se reproducen los cuatro ADR con estilos editoriales y tablas. Su estado propuesto o pendiente se conserva; las expresiones históricas sobre trabajo futuro no equivalen a constatación de la implementación actual.

ADR-001 Estructura y límites: Laravel y PostgreSQL

• Estado: propuesto; revisión G2 pendiente. No autoriza implementación mientras G1 esté pendiente.

• Fecha y versión: 2026-10-14, v0.1.

• Elaboración: Codex a solicitud de Conde José; no acredita trabajo o aprobación humana.

• Fuentes: examen oficial §§2–6, 8–12; SPEC-01 a SPEC-05 0.3-draft; ADR-004 y contrato IA de la rama docs/g2-vega-ia, commit a13aa17.

Contexto y restricciones

Dos organizaciones, cuatro roles y ocho cuentas ficticias. El sistema debe mantener consistencia de stock, reservas, estados, resultado idempotente y auditoría; demostrar aislamiento y transacciones con base real. La IA es opcional para operar, sin herramientas privilegiadas, y su aprobación no ejecuta operaciones de negocio. El usuario solicita Laravel + PostgreSQL y monolito modular. Esto sustituye la propuesta tecnológica inicial TypeScript/Express para este diseño; no se presenta como exigencia del docente.

Alternativas consideradas

Alternativa	Beneficio	Coste / restricción
Laravel + PostgreSQL, monolito modular	Un despliegue, transacción local compartida, autenticación/validación del framework	Requiere disciplina de dependencias y pruebas PostgreSQL; revisar competencia PHP del equipo
React/Express/TypeScript + PostgreSQL	Coincide con propuesta inicial, tipos compartidos	Dos builds y mayor coordinación de sesión/frontend; alternativa válida si el equipo la prefiere
Microservicios	Despliegue independiente	Consistencia distribuida y complejidad innecesaria para examen y equipo
Laravel + MySQL	Compatible con Laravel y transacciones	Requiere adaptar oráculos/entorno; se elige un solo motor real para CI y demo

Criterios de elección

Consistencia transaccional verificable, mínima complejidad operativa, límites claros, autorización centralizada, integración IA reemplazable y arranque reproducible RNF04. Evitar servicios pagados obligatorios y funcionalidades fuera de alcance.

Decisión y justificación

Diseñar un monolito modular Laravel, PostgreSQL único y UI Blade del mismo origen como propuesta de mínima complejidad, sin SPA adicional obligatoria. Docker Compose previsto con aplicación y PostgreSQL; versiones compatibles de PHP/Laravel/PostgreSQL se fijarán en G2 antes de implementación junto con composer.lock y lockfile de assets si aplica. No se inventan lockfiles sin resolver dependencias.

Módulo previsto	Responsabilidad y dueño de datos	Dependencias permitidas
Identity	Sesiones, hash, identidad/rol/org; ocho cuentas ficticias	Infraestructura de persistencia; ADR-003
Requests	Cabecera, líneas y validaciones; crear/editar/enviar borrador propio	Identity, catálogo Inventory, Audit
Inventory	Existencia física/reservada, reserva, despacho y liberación	Requests, Identity, Idempotency, Audit; ADR-002
Queries	Listados, filtros, tablero, inventario e historial autorizado	Lecturas con alcance del servidor; sin mutación
Audit	Eventos append-only de transición/aprobación	Transacción compartida; sin API de edición/borrado
Idempotency	Ámbito usuario/org/operación, hash y resultado ≥24h	Autorización previa y transacción Inventory
AI	Selección, whitelist, adaptador, validación, fallback y aprobación	Identity, lectura Requests, Audit; ADR-004
Operations	Health, readiness y logs estructurados sanitizados	Readiness comprueba PostgreSQL; no depende del proveedor IA

Ubicación propuesta: app/Modules/<Module>/{Application,Domain,Infrastructure,Http}; routes/api.php y vistas Blade. Controladores delgados llaman casos de uso. No importar controladores de otro módulo ni mutar datos ajenos mediante modelos desde la UI. Queries usa proyecciones; AI no obtiene una interfaz de mutación de solicitudes/inventario. Evitar repositorios genéricos innecesarios; solo introducir interfaces en fronteras que deben

sustituirse/probarse, como proveedor IA.

Una única transacción PostgreSQL confirma estado, inventario, auditoría y resultado idempotente. Bloquear solicitud y filas de stock en orden estable; ADR-002 debe concretar aislamiento, deadlocks, hash y retención. No invocar al proveedor IA dentro de una transacción de inventario. Aprobar resumen usa su propia transacción de resumen+evento sin escribir stock.

Fronteras de confianza y alcance

Navegador y observaciones no confiables; API resuelve identidad y filtra organización antes de exponer datos. PostgreSQL no es accesible al navegador. Credencial del proveedor solo en backend, sin nombres/secretos/datos ajenos en payload. Respuesta IA se valida y se presenta escapada. Sesión revocable/cookie y controles CSRF son provisionales hasta ADR-003; contrato IA conserva su esquema original.

Fuera de alcance: usuarios masivos, recuperación de contraseña, GPS/rutas, devoluciones, ajustes de stock por API y decisiones automáticas de IA. El coordinador reporta respuesta afirmativa de la profesora a CL-16/17/18: Coordinador también lee inventario e historial de su organización; Solicitante lee historial y tablero de sus propias solicitudes sin inventario. Bodega no recibe acceso a auditoría. Fecha/canal y evidencia original pendientes; la decisión se registra como reportada y las SPEC afectadas requieren nueva revisión.

Consecuencias y riesgos

Un único despliegue simplifica evaluación; el mismo motor de base se usa en demo y pruebas. Una caída del proceso afecta toda la aplicación, aceptable para este alcance y documentada en runbook futuro. El acoplamiento de modelos y escrituras cruzadas se controla mediante revisión de módulos. Las transacciones no aseguran por sí solas concurrencia/idempotencia: deben ejecutarse los oráculos. G1 pendiente y permisos aún abiertos impiden considerar final el diseño.

RF y AC afectados

RF01–RF12, RNF01–RNF06; todos los AC de SPEC-01–05 según matriz. Contrato contracts/openapi.yaml; diagramas docs/architecture/contexto.md y componentes.md. ADR-002/003 aún pendientes; ADR-004 existente no se aprueba por referencia.

Verificación de la decisión

Pruebas previstas, no ejecutadas: aislamiento 2 lecturas/2 escrituras; reserva parcial rechazada y rollback real; dos reservas competidoras PostgreSQL; replay/conflicto/TTL; evento atómico; fallo IA sin impedir transiciones; clon limpio ≤15min (descargas medidas aparte); carga RNF03 y UI RNF05. Revisar dependencias entre módulos y permisos por ruta en G2.

Apoyo técnico: transacciones Laravel (https://laravel.com/framework/docs/database/config), bloqueos pesimistas (https://laravel.com/framework/docs/13.x/queries). Consultados 2026-10-14; versión del producto aún por fijar. La decisión sigue siendo del equipo.

Autor y revisión humana

Revisor independiente, fecha UTC, SHA y decisión: PENDIENTES. Edier revisa límites/datos/transacción y Vega fronteras IA/seguridad, como propuestas de revisión; no se registra participación realizada.

Fuente: docs/adr/ADR-001-estructura-limites.md

ADR-002 Estrategia transaccional, concurrencia e idempotencia

Formato del anexo oficial 06_adr-template.md.

• Estado: propuesto

• Fecha y versión: 2026-10-14, v0.1 (G2)

• Autor: Castro Edier, con asistencia de IA (registro AI-005)

• Depende de: ADR-001 (Laravel + PostgreSQL, monolito modular; módulos Inventory, Requests, Idempotency y Audit) y contrato contracts/openapi.yaml (rama docs/g2-architecture, e63ebf5)

Contexto y restricciones

• RF05: la reserva cubre todas las líneas o ninguna; disponible = físico − reservado; las tres cantidades nunca negativas; solo desde ENVIADA; si falta stock en una línea, 409 sin cambios.

• RF06: cancelar RESERVADA libera exactamente su reserva; despachar baja físico y reservado; ENTREGADA y cancelar ENVIADA no tocan inventario.

• RF07: reserva transaccional segura ante concurrencia, con Idempotency-Key; misma clave, usuario, organización, operación y contenido repiten el resultado; contenido distinto, 409; resultado conservado al menos 24 h.

• Condiciones de consistencia (§3): dos reservas que compiten por stock insuficiente no pueden tener éxito ambas; un fallo antes del commit no deja reserva parcial; una segunda reserva con otra clave devuelve 409; la clave se procesa después de autenticar y autorizar.

• RF09: estado, inventario y evento de auditoría se persisten de forma consistente.

• RNF02: verificado contra una base real (PostgreSQL), no con mocks.

• Oráculos oficiales (acceptance-oracles.md): con KIT-ALIMENTO de ORG-A en físico 10, reservar A-001 (7) deja 10/7/3; dos reservas simultáneas de 7 dejan una exitosa, otra 409 y 10/7/3.

Alternativas consideradas

Control de concurrencia del stock

Opción	Cómo funciona	Ventajas	Desventajas
A. Bloqueo pesimista	SELECT … FOR UPDATE sobre la solicitud y las filas de stock en orden de SKU, en READ COMMITTED (Laravel lockForUpdate())	Correcto con varias líneas; fácil de razonar, explicar y probar; sin reintentos en el caso normal	Las reservas del mismo SKU esperan en fila; requiere orden fijo de bloqueo para evitar deadlocks
B. UPDATE condicional	UPDATE … SET reservado = reservado + n WHERE fisico - reservado >= n y revisar filas afectadas	Sin bloqueos explícitos	Con varias líneas hay que deshacer las ya actualizadas; más difícil de garantizar «todas o ninguna»
C. Bloqueo optimista	Columna version; si cambió, reintentar	Sin esperas	Muchos reintentos cuando hay competencia, que es justo el caso a probar
D. SERIALIZABLE + reintentos	PostgreSQL aborta transacciones en conflicto (40001)	Garantía fuerte	Reintentos obligatorios en todo el código; errores más difíciles de diagnosticar

Almacén de idempotencia

Opción	Ventajas	Desventajas
Tabla en PostgreSQL dentro de la misma transacción	El resultado se guarda si y solo si se confirman los efectos; sin servicios extra	Requiere limpieza periódica
Caché externa (Redis)	Rápida	No es transaccional con la base: podría guardar un resultado sin efectos o al revés; servicio adicional

Opción	Ventajas	Desventajas
Middleware fuera de la transacción	Genérico	Mismo problema de consistencia que Redis

Criterios de elección

1. Cumplir los oráculos oficiales en cualquier orden de llegada de las peticiones.

2. Atomicidad de estado, inventario, auditoría y resultado idempotente.

3. Que el mecanismo se pueda probar de forma determinista contra PostgreSQL real.

4. Mínima complejidad.

Decisión y justificación

Se adoptan el bloqueo pesimista (A) y la tabla de idempotencia en la misma transacción.

Reserva (POST /api/requests/{requestId}/reserve)

Paso	Acción	Resultado si falla
1	Autenticar; resolver la solicitud dentro de la organización del usuario	401 / 404 (no se guarda)
2	Autorizar rol Coordinador	403 (no se guarda)
3	Validar cuerpo {} y cabecera Idempotency-Key (1–128 caracteres)	422 (no se guarda)
4	BEGIN (READ COMMITTED) y SET LOCAL lock_timeout = '3s'	—
5	pg_advisory_xact_lock(hash(org, usuario, 'reserve', clave)): serializa peticiones con la misma clave	—
6	Buscar el registro de idempotencia del ámbito. Si existe y no venció: misma huella → devolver código y cuerpo guardados sin efectos; huella distinta → 409	Replay o 409 (no se guarda de nuevo)
7	SELECT … FOR UPDATE de la solicitud	—
8	Si el estado no es ENVIADA → 409	409 guardado en el registro de idempotencia
9	SELECT … FOR UPDATE de las filas de inventario de sus SKU, ordenadas por SKU	—
10	Comprobar, para cada línea, SKU activo y fisico − reservado ≥ cantidad	409 guardado; ninguna fila modificada
11	reservado += cantidad por línea; estado RESERVADA; evento de auditoría; registro de idempotencia con 200 y cuerpo	—

Paso	Acción	Resultado si falla
12	COMMIT	Cualquier excepción antes: ROLLBACK total y 500 con correlationId, sin registro (H-E01)

Detalles:

• Huella: SHA-256 del JSON canónico {"operation":"reserve","requestId":…,"body":{}} con claves ordenadas.

• Ámbito de la clave: UNIQUE (organization_id, user_id, operation, idempotency_key). La misma clave en otra organización o de otro usuario es independiente (AC-03-12).

• Retención: expires_at = created_at + 24 h. Se repite el resultado mientras now < expires_at. Al vencer, el registro se reemplaza y la operación se reevalúa (AC-03-11, supuesto CL-11). Un comando programado borra los registros con más de 7 días.

• Respuestas guardadas (CL-04): 200 y 409 de negocio. No se guardan 401, 403, 404, 422 ni 500, que se pueden reintentar con la misma clave. Consecuencia (H-E03): un 409 por falta de stock se repite durante 24 h; para reintentar después de liberar stock, el cliente usa una clave nueva.

• Segunda reserva con otra clave: el paso 8 la rechaza con 409 porque el estado ya no es ENVIADA (AC-03-14).

• Por qué funciona la competencia en READ COMMITTED: cuando la segunda transacción obtiene el bloqueo de la fila de stock, PostgreSQL le entrega la versión ya confirmada por la primera (reservado = 7), así que su comprobación ve disponible 3 y responde 409.

Otras transiciones

Despachar, entregar, cancelar y enviar usan la misma transacción, sin Idempotency-Key (RF07 solo la exige para reservar): bloquear la solicitud, comprobar estado y rol, bloquear el stock en orden de SKU si se modifica, actualizar, registrar el evento y confirmar.

Transición	Actor (§2)	Efecto en stock
Enviar BORRADOR → ENVIADA	Solicitante dueño	Ninguno
Reservar ENVIADA → RESERVADA	Coordinador	reservado += cantidad
Despachar RESERVADA → DESPACHADA	Bodega	fisico −= cantidad y reservado −= cantidad
Entregar DESPACHADA → ENTREGADA	Coordinador	Ninguno
Cancelar ENVIADA → CANCELADA	Solicitante dueño	Ninguno
Cancelar RESERVADA → CANCELADA	Solicitante dueño	reservado −= cantidad
Cualquier otra	—	409 sin cambios

Una carrera entre despacho y cancelación de la misma reserva (H-E02) se resuelve con el bloqueo de la solicitud: la primera gana y la segunda ve el nuevo estado y recibe 409.

Orden de bloqueo y deadlocks

Siempre: bloqueo consultivo de la clave (solo en reservas) → fila de la solicitud → filas de stock por SKU ascendente. Con un orden único no se forman ciclos. Como defensa, DB::transaction($callback, 3) de Laravel reintenta hasta 3 veces si PostgreSQL detecta un deadlock (40P01). Si se agota el lock_timeout, la respuesta es 500 controlado, sin guardar, y se puede reintentar con la misma clave.

Restricciones en la base (defensa en profundidad)

• CHECK (fisico >= 0 AND reservado >= 0 AND reservado <= fisico) en inventario: si un error de código intentara dejar stock negativo, la base lo rechaza y la transacción se revierte.

• CHECK (cantidad BETWEEN 1 AND 500) en las líneas y CHECK del estado con los seis valores.

• Llaves foráneas compuestas con organization_id entre solicitud, líneas e inventario: una línea no puede apuntar a stock de otra organización.

• Auditoría append-only: un trigger rechaza UPDATE y DELETE en audit_events.

Detalle en datos (../architecture/datos.md), estados (../architecture/estados.md) y secuencia de reserva concurrente (../architecture/secuencia-reserva-concurrente.md).

Consecuencias y riesgos

• (+) Los oráculos se cumplen sin importar el orden de llegada; los efectos y el resultado idempotente se confirman juntos.

• (+) Las restricciones de la base detienen errores de código antes de que corrompan el inventario.

• (−) Las reservas del mismo SKU se procesan una a la vez; aceptable para el volumen del caso. RNF03 mide listados y tablero, no reservas.

• (−) Las restricciones y el trigger dependen de PostgreSQL; las pruebas deben usar PostgreSQL real (ver docs/testing/estrategia-pruebas.md).

• Riesgo: un bloqueo mantenido demasiado tiempo → lock_timeout de 3 s y transacciones cortas, sin llamadas externas dentro (la IA nunca se invoca dentro de una transacción de inventario, ADR-001).

Coherencia con el contrato

• Idempotency-Key y la política 200/409 guardados coinciden con contracts/openapi.yaml.

• Observación para el contrato (H-E05): las descripciones de dispatch, deliver y cancel terminan con «Misma reserva con otra clave devuelve 409», que no aplica porque esas operaciones no usan clave. Conviene quitar la frase.

RF y AC afectados

RF02, RF04, RF05, RF06, RF07, RF09, RNF02; AC-03-01 a AC-03-16, AC-04-03, AC-04-08; hallazgos H-E01 a H-E03.

Verificación de la decisión

Pruebas previstas contra PostgreSQL real (oráculos escritos antes):

Prueba	AC	Cómo
Reserva exitosa 10/7/3 y un evento	AC-03-01	Seed restablecido; consulta directa a la base
Línea insuficiente sin cambios	AC-03-02	Snapshot antes y después
Dos reservas simultáneas	AC-03-03, 03-08	Dos procesos reales con barrera, ≥ 20 repeticiones; siempre una 200 y una 409, 10/7/3 y un evento

Prueba	AC	Cómo
Replay y conflicto de clave	AC-03-04, 03-10	Misma respuesta y un solo evento; otro contenido → 409
Expiración a 24 h	AC-03-11	Reloj controlado (travelTo)
Ámbito de la clave	AC-03-12	Misma clave en ORG-B no devuelve la respuesta de ORG-A
Segunda reserva con otra clave	AC-03-14	409 y reservado sin cambios
Fallo antes del commit	AC-03-09	Excepción inyectada al escribir el evento: estado, stock y registro de idempotencia sin cambios
Carrera despacho / cancelación	H-E02	Dos procesos; estado final coherente con el que ganó
Restricción de stock	RNF02	Un UPDATE directo que deje reservado > fisico falla
Auditoría inmutable	AC-04-08	UPDATE o DELETE sobre audit_events falla

Autor y revisión humana

• Autor: Castro Edier (asistido por IA, AI-005).

• Revisión humana: pendiente de una persona distinta del autor en la revisión G2.

Fuente: docs/adr/ADR-002-transacciones-idempotencia.md

ADR-003: Autenticación, Sesiones y Aislamiento Multitenant (ORG-A / ORG-B)

• Estado: Propuesto

• Fecha: 2026-10-14

• Autora: Carolina Cantillo

• Revisión Humana: Pendiente

• Requisitos: RF01, RF02, RNF01, SPEC-01 (AC-01-01 a AC-01-13)

• Atención a Hallazgos:

- H-V05: Precisión de respuestas HTTP 403 vs 404 para evitar enumeración y fuga de datos cross-tenant.

- H-V06: Protección estricta contra ataques CSRF mediante verificación de tokens y cookies SameSite/SameOrigin.

Contexto y Problema

NexoEntrega 360 requiere aislar completamente los recursos entre ORG-A y ORG-B bajo cuatro roles (Solicitante, Coordinador, Bodega, Auditor). Se deben precisar los parámetros de sesión, logout, algoritmo de hashing definitivo y protección contra vulnerabilidades CSRF.

Opciones Evaluadas

1. Laravel Sessions (Cookie HTTP-Only, SameSite=Lax/Strict) + Scope Tenant en Eloquent.

2. Tokens Sanctum SPA / API Bearer Tokens.

3. Multi-tenancy con esquemas de BD separados.

Decisión Seleccionada

Adoptamos la Opción 1: Sesiones basadas en cookies HTTP-Only con Middleware de Organización, con las siguientes precisiones técnicas definitivas:

Especificación Técnica

• Algoritmo de Hashing Definitivo: Bcrypt con factor de costo 12 para todas las contraseñas almacenadas.

• Sesión y Cookie: Duración de sesión configurable (config/session.php: lifetime = 120 minutos), expire_on_close = true, http_only = true, same_site = lax. El flag secure = true estará habilitado por entorno en producción HTTPS, manteniendo secure = false únicamente cuando la demo local corra sobre HTTP estándar.

• Logout: Invalidación explícita de sesión (Auth::logout(), session()->invalidate(), session()->regenerateToken()).

• Protección CSRF (H-V06): Verificación activa de token CSRF mediante ValidateCsrfToken en todas las peticiones de mutación HTTP (POST, PUT, PATCH, DELETE).

• Manejo de Errores 403 vs 404 (H-V05): Si un recurso existe pero pertenece a otra organización, el servidor retornará HTTP 404 Not Found en lugar de 403 Forbidden para evitar la enumeración maliciosa de identificadores.

Consecuencias y Validación

• Aislamiento multitenant robusto a nivel de backend. Evaluado contra criterios AC-01-01 a AC-01-13.

Fuente: docs/adr/ADR-003-autenticacion-aislamiento.md

ADR-004 Integración del asistente de IA y degradación

Formato del anexo oficial 06_adr-template.md.

• Estado: propuesto

• Fecha y versión: 2026-10-14, v0.1 (G2)

• Autor: Vega José, con asistencia de IA (registro AI-004)

• Depende de: ADR-001 (estructura y tecnología; el equipo acordó Laravel con PostgreSQL el 2026-10-14; falta registrarlo en ADR-001) y ADR-003 (identidad y sesión)

Contexto y restricciones

El coordinador pide un resumen de hasta 20 solicitudes ENVIADA de su organización (RF10). La salida del modelo debe cumplir contracts/ai-output.schema.json y la validación de pertenencia (RF11). El resumen es un borrador que solo el coordinador aprueba, y aprobarlo no cambia inventario, estado ni prioridad (RF12). Restricciones vinculantes:

• Plazo de 5 s; salida inválida, timeout o fallo del proveedor devuelven un mensaje controlado y un resumen determinista alternativo (RF12).

• El proveedor recibe solo requestId, zona, prioridad, fecha requerida, estado y observaciones (RF10).

• El modelo no recibe capacidad de escribir inventario ni de invocar operaciones privilegiadas; un prompt que lo prohíbe no basta (§10).

• CI usa fixtures deterministas, sin servicio de pago (RNF06, AC-05-14).

• Debe demostrarse una salida de un LLM real que pase por el mismo adaptador y validador (§10). El equipo eligió una API con plan gratuito.

• Las observaciones son datos no confiables (untrusted-observation.txt, OWASP LLM01).

Alternativas consideradas

Arquitectura de la integración

Opción	Descripción	Ventajas	Desventajas
A. Llamada directa	El controlador llama al proveedor y muestra la respuesta	Poco código	No se puede probar sin red; acopla al proveedor; validación dispersa; incumple «proveedor intercambiable» (§10)
B. Adaptador + validador + fallback	Interfaz AiProvider con varias implementaciones; un servicio orquesta proyección, plazo, validación y fallback	Intercambiable; CI con fixtures; validación en un único punto; degradación controlada	Más clases y pruebas
C. Llamada desde el navegador	El frontend llama al proveedor	Sin carga en el servidor	Expone la clave; el servidor no valida pertenencia; descartada por seguridad

Origen de la salida de LLM real

Opción	Ventajas	Desventajas
API con plan gratuito (elegida por el equipo)	Invocación real y demostrable; sin costo	Requiere clave en .env; cuotas y errores 429; los planes gratuitos cambian
Modelo local (Ollama)	Sin clave ni cuota	Instalación pesada; depende del hardware de cada integrante
Reproducción declarada	Reproducible y sin clave	No demuestra invocación en vivo

Proveedor de la API gratuita. Gemini (modelos Flash del plan gratuito de Google AI Studio) o Groq. Ambos ofrecían plan gratuito en 2026, pero sus límites cambian: se comprueban en la consola del proveedor al implementar y no se fijan en el código.

Criterios de elección

1. Cumplir RF10–RF12 y RNF06 con pruebas deterministas.
2. Seguridad: clave fuera del repositorio y del navegador; validación en el servidor.
3. Demostrar una salida real sin depender de ella para que el sistema funcione.
4. Mínima complejidad que cumpla lo anterior.

Decisión y justificación

Se adopta la opción B con estas piezas (nombres orientativos en Laravel):

Pieza	Responsabilidad
AiProvider (interfaz)	complete(string $prompt, int $timeoutMs): string; devuelve el texto crudo o lanza AiTimeoutException / AiProviderException
GeminiProvider / GroqProvider	Cliente HTTP de Laravel con timeout(5); clave leída de config('ai.key') (variable AI_API_KEY en .env)
FixtureProvider	Devuelve el rawOutput o simula el transport de ai-provider-fixtures.json; lo usa CI
ReplayProvider	Devuelve una respuesta real capturada y guardada en evidence/ai-replay/ con entrada, salida, modelo, fecha y origen

Pieza	Responsabilidad
NullProvider	Sin proveedor configurado: lanza AiProviderException para activar el fallback
AiOutputValidator	1) JSON estricto; 2) esquema ai-output.schema.json; 3) en código: cada requestId pertenece a la selección y no se repite
FallbackSummarizer	Resumen determinista con conteos por prioridad y zona y la fecha requerida más próxima; recommendations vacío (CL-08)
AiSummaryService	Orquesta: autoriza Coordinador, valida selección, proyecta seis campos, construye el prompt, llama con plazo, valida, guarda borrador u origen fallback

El proveedor se elige con AI_PROVIDER=gemini|groq|replay|fixture|none en .env. El valor por defecto en .env.example es none, así que la demo funciona sin clave usando el fallback.

Uso del LLM real. La API gratuita se usa en una demostración manual. La respuesta obtenida se guarda además como captura de reproducción para que la evidencia sea repetible aunque la cuota o la clave no estén disponibles cuando el docente evalúe. La captura se declara como reproducción, sin afirmar una invocación en vivo (§10).

Reglas de validación de la selección (orden propuesto en H-V02, CL-19): formato de la lista 1–20 IDs únicos (422) → pertenencia a la organización (404) → estado ENVIADA (409). El proveedor no se invoca si falla cualquiera.

Construcción del prompt. Instrucciones fijas del sistema y, separado, un bloque JSON con los seis campos. Las observaciones van dentro de ese bloque como datos. Se pide responder solo JSON con el formato del esquema y, si el proveedor lo permite, se activa su modo de salida JSON. Esto reduce errores, pero no sustituye la validación en código.

Plazo. El cliente HTTP corta a los 5 s. La prueba usa reloj controlado y una tolerancia máxima propuesta de 250 ms (H-V01, por confirmar en el plan de pruebas).

Persistencia (CL-05). Tabla de resúmenes: id, organización, coordinador, IDs seleccionados, summary, recommendations, origen (tipo, proveedor, modelo, fixture), estado BORRADOR o APROBADO, aprobado por y fecha UTC. Tabla de intentos: fecha, origen, resultado (válido, inválido, timeout, error) y motivo sanitizado; nunca el prompt con secretos ni la clave.

Aprobación. En una transacción: estado APROBADO, aprobador, fecha UTC y evento de auditoría con los campos de RF09. Un resumen alternativo también se puede aprobar, conservando su origen (H-V03). Aprobar dos veces devuelve 409 sin segundo evento (H-V04).

Presentación. summary y reason se muestran con escape de Blade ({{ }}), nunca con {!! !!}. La pantalla etiqueta el borrador como «Asistencia de IA» y muestra su origen.

Consecuencias y riesgos

• (+) CI y la demo funcionan sin red ni clave (RNF06); el flujo principal no depende de la IA.

• (+) Cambiar de proveedor solo requiere otra implementación de AiProvider.

• (−) Más código y pruebas que una llamada directa.

• Riesgo: cuota agotada o error 429 del plan gratuito → fallback controlado; evidencia real en la captura de reproducción.

• Riesgo: fuga de la clave → solo en .env (ignorado por Git), detección de secretos en CI (CI-11) y nunca en logs.

• Riesgo: el plan gratuito puede usar los datos enviados para mejorar el servicio → solo se envían datos ficticios del examen.

• Riesgo: inyección de instrucciones → el modelo no tiene herramientas; la salida se valida contra el esquema y la selección; las acciones solo ocurren por operaciones normales del coordinador.

RF y AC afectados

RF02, RF09, RF10, RF11, RF12, RNF01, RNF06; AC-05-01 a AC-05-14; hallazgos H-V01 a H-V04 y H-V07.

Verificación de la decisión

Prueba prevista	AC	Cómo
Payload solo con seis campos y la selección	AC-05-01	Proveedor espía que guarda el prompt recibido
Siete fixtures oficiales	AC-05-02, 03, 06, 07, 08, 14	FixtureProvider con cada id; resultado igual a su campo expected
Selección inválida no invoca al proveedor	AC-05-05	Proveedor espía con contador de llamadas en 0
Plazo de 5 s	AC-05-03	Reloj controlado; corte ≤ 5 s + tolerancia
Marcado escapado con salida válida	AC-05-08 (V-09b)	Prueba de vista: el HTML contiene <script>
Aprobación sin efectos de negocio	AC-05-04, 05-12	Snapshot de solicitudes e inventario antes y después
Salida real por el mismo validador	AC-05-13	ReplayProvider con la captura real
CI sin red ni clave	AC-05-14	El workflow no define AI_API_KEY y usa AI_PROVIDER=fixture

Autor y revisión humana

• Autor: Vega José (asistido por IA, AI-004).

• Revisión humana: pendiente de una persona distinta del autor en la revisión G2.

Fuente: docs/adr/ADR-004-integracion-ia-degradacion.md

4. Uso crítico de IA y verificación

La bitácora diferencia el uso de IA para preparar el proyecto del asistente integrado en la aplicación. Se incluyen siete registros existentes; la autoría y las verificaciones se reproducen como están documentadas, sin crear decisiones humanas nuevas. El asistente actual solo produce fallback: falta demostrar el proveedor real y su validación estricta.

AI-001-cotejo-oficial-g1

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

• ID y fecha UTC: AI-001, 2026-10-14T03:29Z a 2026-10-14T04:00Z (aprox.)

• Autor: Castro Edier (202311254074), quien solicitó la intervención y entregó los archivos oficiales

• Etapa: especificación y revisión crítica (G1)

• Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai con espacio de trabajo de archivos y Python

• RF y AC: RF01–RF12 y RNF01–RNF06; todos los AC de SPEC-01 a SPEC-05

• Contexto y versiones de archivos: rama docs/g1-specifications en 6fa084c (SPEC 0.2-draft); Examen_Estudiantes_SDD_IA.pdf SHA-256 bad0b194…cc49; Anexos_Estudiantes_SDD_IA.zip SHA-256 26890046…bb3e (hashes completos en docs/examen-oficial/inventario.md)

Objetivo

Inventariar los documentos oficiales, cotejar RF01–RF12 y RNF01–RNF06 contra las cinco SPEC del PR #1, corregir los problemas documentales que no requieren decisión del cliente, dejar pendientes las que sí, y regenerar cotejo, matriz y JSON comprobando su coherencia.

Prompt enviado

Instrucción del coordinador del equipo, entregada por Edier junto con el PDF y el ZIP oficiales:

voy a proporcionarte los documentos oficiales del examen NexoEntrega 360. Necesito que revises cada documento recibido y actualices el inventario de docs/examen-oficial/. Conserva los nombres originales y diferencia los archivos oficiales de las transcripciones o notas del equipo. Compara exhaustivamente los requisitos RF01–RF12 y RNF01–RNF06 contra las cinco SPECS del PR #1. Identifica omisiones, contradicciones, ambigüedades y criterios de aceptación insuficientes. Corrige los problemas documentales que no requieran decisiones del cliente y deja pendientes las aclaraciones que sí dependan del docente. Actualiza el cotejo oficial, la matriz de cobertura y los JSON derivados, comprobando su coherencia. No declares G1 aprobado ni fusiones el PR hasta que una persona distinta del autor revise la versión final. Cuando termines, entrégame un resumen con los requisitos cubiertos, las diferencias encontradas, las correcciones y el SHA exacto que deben revisar mis compañeros.

Salida relevante

• Originales guardados sin cambios en docs/examen-oficial/ con SHA256SUMS.txt e inventario.

• Cotejo en docs/reviews/cotejo-oficial-G1.md: en 0.2, 5 requisitos coincidían, 7 estaban incompletos, 5 contradecían el enunciado (matriz de permisos, prioridades, actores de transición, selección y campos de IA, RNF04) y 1 era ambiguo; 24 diferencias D-01 a D-24.

• SPEC 0.3-draft en el formato del anexo 13 con entradas tipadas y AC dado/cuando/entonces; 68 AC (antes 57), con requisitos y tipo de escenario por AC.

• Exportador y pruebas documentales reescritos; matriz y docs/evidence/traceability.csv generados desde la fuente única.

• Registro de aclaraciones reclasificado; CL-16, CL-17 y CL-18 requieren decisión del docente.

• Diferencias no corregidas: D-20 (CI de coincidencia JSON), D-21 (formato de la constitution) y D-22 (envío de preguntas al docente).

Decisión humana

Registrada por Edier tras revisar la salida:

Cambio	Decisión de Edier (aceptada / corregida / descartada)	Motivo	Fecha UTC
Inventario y originales oficiales	Aceptada	Los archivos son los que descargó de la plataforma oficial	2026-10-14
Diferencias D-01 a D-24 y su clasificación	Aceptada	Revisó las diferencias contra el PDF y está de acuerdo	2026-10-14
SPEC-03 (área asignada a Edier): actores, oráculos, AC-03-14 a AC-03-16	Aceptada	Coinciden con la p. 4 del PDF y con acceptance-oracles.md	2026-10-14
Migración de formato (D-15) y nuevo exportador	Aceptada	Revisada junto con SPEC-03	2026-10-14
Supuestos de equipo (CL-02, CL-04, CL-11, CL-19)	Aceptada como propuesta	Quedan como propuesta; el equipo debe acordarlos	2026-10-14

La aprobación de G1 la hace además una persona distinta del autor; esta intervención no aprueba sus propias salidas.

Verificación

Ejecutada por el asistente en su espacio de trabajo (salidas completas en docs/evidence/g1-validation.md, ejecución 2):

• python scripts/export_specs.py --check: 5 SPEC y 68 AC coherentes.

• python scripts/build_coverage.py --check: matriz y traza coherentes.

• python -m unittest discover -s scripts -p "test_*.py" -v: 14 pruebas OK.

• sha256sum -c SHA256SUMS.txt: 29 archivos OK.

Verificación humana pendiente: Edier y el revisor deben repetir los comandos y contrastar el cotejo con el PDF.

Límites

• El cotejo lo produjo un modelo de IA; puede contener interpretaciones erróneas. Cada fila cita página para facilitar la comprobación.

• No se ejecutó ninguna prueba de producto: no existe aplicación.

• Los supuestos marcados «Decisión del equipo» no han sido acordados por el equipo.

• No se incluyeron claves, credenciales ni datos reales. El anexo untrusted-observation.txt se trató como dato de prueba, no como instrucción.

AI-002-escenarios-inventario

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

• ID y fecha UTC: AI-002, 2026-10-14T05:15Z

• Autor: Castro Edier (202311254074)

• Etapa: revisión crítica de especificación y diseño de pruebas (G1)

• Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai

• RF y AC: RF02, RF04–RF07, RF09, RNF02; AC-03-01 a AC-03-16, AC-01-09

• Contexto y versiones de archivos: commit 560c9cbe7972fcfe2258406ca7ed5f094b5a50e3 (SPEC-03 0.3-draft); anexos acceptance-oracles.md y fixture-scenarios.json; guía docs/team/instrucciones-edier.md

Objetivo

Preparar el aporte individual de Edier: revisar SPEC-03 contra las invariantes de inventario y redactar los escenarios previstos de reserva, concurrencia, cancelación, despacho, entrega, fallo antes del commit e idempotencia, con datos iniciales, esperado y efectos persistidos.

Prompt enviado

terminemos con lo mio

Contexto dado en la misma conversación: la guía instrucciones-edier.md (tabla de escenarios con AC, datos iniciales, actor, acción, respuesta esperada, estado, stock, eventos y fuente; observado «no ejecutado»; registrar ambigüedades como preguntas).

Salida relevante

• docs/reviews/aportes/edier-G1.md: seis comprobaciones documentales, 17 escenarios previstos (E-01 a E-17) con oráculos del anexo y cuatro hallazgos (H-E01 a H-E04).

• Hallazgos principales: falta el código HTTP del fallo inducido antes del commit (H-E01) y no hay AC para la carrera entre despacho y cancelación de la misma reserva (H-E02).

Decisión humana

PENDIENTE. Edier debe revisar cada escenario y hallazgo y anotar aquí si los acepta, corrige o descarta, con su motivo y fecha UTC.

Verificación

• Las cantidades esperadas se contrastaron con acceptance-oracles.md y con el seed de fixture-scenarios.json.

• python scripts/export_specs.py --check y python scripts/build_coverage.py --check sin errores sobre el SHA revisado.

• Verificación humana pendiente: Edier debe comprobar los escenarios contra la p. 4 del enunciado.

Límites

Los escenarios son previstos; ninguno se ejecutó. Los hallazgos son propuestas para el equipo, no decisiones del cliente. Sin datos reales ni secretos.

AI-003-revision-ia-seguridad

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

• ID y fecha UTC: AI-003, 2026-10-14T14:37Z a 2026-10-14T15:15Z (aprox.)

• Autor: Vega José (202321256198)

• Etapa: revisión crítica de especificación y diseño de pruebas (G1)

• Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai

• RF y AC: RF01, RF02, RF10–RF12, RNF01, RNF06; AC-01-01 a AC-01-13 y AC-05-01 a AC-05-14

• Contexto y versiones de archivos: commit cf9d5f5d905dee3a3774c623283c7045271dbe60 (SPEC 0.3-draft); anexos ai-output.schema.json, ai-provider-fixtures.json, untrusted-observation.txt y fixture-scenarios.json; guía docs/team/instrucciones-vega.md

Objetivo

Preparar el aporte individual de Vega: revisar SPEC-01 y SPEC-05 contra el enunciado y los anexos de IA, redactar los casos previstos de IA, seguridad y aislamiento, y proponer el checklist de CI, con la IA como guía que corrige errores.

Prompt enviado

Prompt de trabajo (2026-10-14T15:11Z):

Yo soy José Vega, me voy a encargar de la integración de IA, permisos y pruebas de calidad. Quiero que me guies en el proceso, y me corrijas si me equivoco en algo.

Antes, a las 14:37Z, Vega pidió que se le explicara su parte paso a paso; con esa explicación y la salida real de sus comandos se preparó un primer borrador. El prompt de trabajo motivó una nueva revisión del borrador contra las fuentes antes de publicarlo.

Salida relevante

• docs/reviews/aportes/vega-G1.md: ocho comprobaciones documentales, 26 casos previstos (V-01 a V-25, con V-09 dividido en V-09a y V-09b), siete hallazgos (H-V01 a H-V07) y un checklist de CI con 12 pasos.

• Corrección hecha en la revisión: el caso de inyección del primer borrador esperaba ver el <script> escapado usando el fixture AI-INJECTION, pero esa salida se rechaza entera por el ID ajeno y nunca se muestra. Se separó en V-09a (rechazo y fallback) y V-09b (salida válida con marcado, mostrada escapada), y se registró H-V07 porque AC-05-08 tiene el mismo problema.

• Otros hallazgos: falta cuantificar la tolerancia del timeout (H-V01), definir el orden de validación de la selección (H-V02) y fijar el esperado de AC-01-07 (H-V05).

Decisión humana

Registrada por Vega tras comprobar la salida contra el enunciado y los anexos:

Cambio	Decisión de Vega (aceptada / corregida / descartada)	Motivo	Fecha UTC
Casos V-01 a V-16 (IA), incluida la división V-09a / V-09b	Aceptada	Comprobó los límites de RF11 (p. 5) en V-06 y V-07 y el campo expected de los siete fixtures de ai-provider-fixtures.json; coinciden	2026-10-14
Casos V-17 a V-25 (permisos y aislamiento)	Aceptada	Comprobó los códigos 401, 403 y 404 contra «Respuestas observables» (p. 3); coinciden	2026-10-14
Cambio	Decisión de Vega (aceptada / corregida / descartada)	Motivo	Fecha UTC
Hallazgos H-V01 a H-V07	Aceptada	Confirmó en specs/SPEC-05.md que AC-05-08 mezcla	2026-10-14

Cambio	Decisión de Vega (aceptada / corregida / descartada)	Motivo	Fecha UTC
		fallback y marcado escapado(H-V07); los demás hallazgosle parecen válidos	
Checklist de CI	Aceptada	Comparado con «Integración continua» (p. 10): están todos los pasos exigidos	2026-10-14

Decisión sobre las SPEC: SPEC-01 y SPEC-05 aprobadas con observaciones sobre el SHA cf9d5f5; los hallazgos H-V01 a H-V07 quedan abiertos para la versión 0.4.

Verificación

• Comandos documentales ejecutados por Vega en Windows con Python 3.12.10 sobre el SHA revisado: 5 SPEC y 68 AC coherentes, matriz coherente, 14 pruebas OK (salida en vega-G1.md).

• Los casos de IA se contrastaron con los siete fixtures del anexo y los límites de ai-output.schema.json.

• Verificación humana pendiente: Vega debe comprobar los casos contra las pp. 3, 5 y 11 del enunciado.

Límites

Los casos son previstos; ninguno se ejecutó. Los hallazgos son propuestas para el equipo, no decisiones del cliente. El texto de untrusted-observation.txt se trató como dato de prueba, no como instrucción. Sin datos reales ni secretos.

AI-004-diseno-ia-g2

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

• ID y fecha UTC: AI-004, 2026-10-14T16:04Z (aprox.)

• Autor: Vega José (202321256198)

• Etapa: diseño (G2)

• Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai

• RF y AC: RF02, RF09–RF12, RNF01, RNF06; AC-05-01 a AC-05-14

• Contexto y versiones de archivos: rama docs/g1-vega-review en 1b3bb37 (SPEC 0.3-draft y revisión G1 de Vega con hallazgos H-V01 a H-V07); anexos ai-output.schema.json y ai-provider-fixtures.json; enunciado §6, §9, §10 y §11

Objetivo

Iniciar la parte de Vega en G2: ADR de integración de IA y degradación, secuencia de consulta de IA con fallo, contrato del asistente y estrategia de pruebas.

Prompt enviado

Ayudame a empezar con el dia dos

Decisiones dadas por Vega antes de redactar, ante dos preguntas de la IA: tecnología del equipo Laravel (después el equipo eligió PostgreSQL); salida de LLM real mediante API con plan gratuito.

Salida relevante

• docs/adr/ADR-004-integracion-ia-degradacion.md: compara tres arquitecturas y tres orígenes de LLM real; decide adaptador + validador + fallback con proveedor configurable (AI_PROVIDER) y clave solo en .env.

• docs/architecture/secuencia-ia-con-fallo.md: diagrama Mermaid con fronteras de confianza y ramas válida, inválida y timeout/error.

• contracts/openapi-ia.yaml: fragmento OpenAPI 3.1.1 con POST /api/ai/summaries y POST /api/ai/summaries/{summaryId}/approve, para integrar en el contrato base.

• contracts/ai-output.schema.json: copia de trabajo del anexo oficial (SHA-256 idéntico al original).

• docs/testing/estrategia-pruebas.md: niveles, herramientas en Laravel, CI y tabla de resultados de los siete fixtures.

Decisión humana

Registrada por Vega tras comprobar cada archivo:

Cambio	Decisión de Vega (aceptada / corregida / descartada)	Motivo	Fecha UTC
ADR-004 (decisión y alternativas)	Aceptada	Se elige la opción B (adaptador + validador + fallback); la C se descarta por seguridad porque expone la clave y el servidor no valida la pertenencia	2026-10-14
Secuencia de IA con fallo	Aceptada	FallbackSummarizer se invoca en las dos ramas exigidas, salida inválida y timeout o error (líneas 41 y 48)	2026-10-14
Contrato openapi-ia.yaml	Aceptada	Límites comparados con RF10 y RF11 (p. 5): maxItems 20 (l. 155), maxLength 240 (l. 171), maxItems 3 (l. 175), maxLength 600 (l. 211) y maxItems 5 (l. 214); coinciden	2026-10-14
Estrategia de pruebas	Aceptada	AI-FOREIGN-ID y AI-INJECTION pasan el esquema y se rechazan por pertenencia; la estrategia prohíbe SQLite y mocks de inventario (§11)	2026-10-14

Verificación

Ejecutada por el asistente en su espacio de trabajo el 2026-10-14:

• openapi-spec-validator sobre contracts/openapi-ia.yaml: válido, OpenAPI 3.1.1, dos rutas.

• Los dos ejemplos de respuesta cumplen el esquema BorradorResumen y sus summary y recommendations cumplen ai-output.schema.json.

• Los siete fixtures oficiales se evaluaron contra el esquema y contra la selección {A-001, A-002}: AI-VALID válido; AI-JSON-BAD JSON roto; AI-EXTRA falla el esquema; AI-FOREIGN-ID y AI-INJECTION pasan el esquema y solo los rechaza la pertenencia; AI-TIMEOUT y AI-ERROR son fallos de transporte.

• contracts/ai-output.schema.json tiene el mismo SHA-256 que el anexo oficial (93365b77…4c53).

Verificación humana pendiente: Vega debe repetir la revisión del diagrama (vista previa Mermaid) y del contrato.

Límites

• El equipo acordó Laravel con PostgreSQL el 2026-10-14; falta registrarlo en ADR-001.

• Los límites del plan gratuito de Gemini o Groq cambian; se verifican al implementar.

• Nada se implementó ni se ejecutó contra un proveedor real. Sin claves ni datos reales.

AI-005-transacciones-g2

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

• ID y fecha UTC: AI-005, 2026-10-14T17:00Z a 17:10Z (aprox.)

• Autor: Castro Edier (202311254074)

• Etapa: diseño (G2)

• Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai

• RF y AC: RF02, RF04–RF07, RF09, RNF02; AC-03-01 a AC-03-16, AC-04-03, AC-04-08

• Contexto y versiones de archivos: rama docs/g2-architecture en e63ebf5 (ADR-001 y contracts/openapi.yaml de José Conde, ADR-004 de Vega); SPEC-03 0.3-draft; anexos acceptance-oracles.md y fixture-scenarios.json; hallazgos H-E01 a H-E03 de docs/reviews/aportes/edier-G1.md

Objetivo

Preparar la parte de Edier en G2: ADR-002 (transacciones, concurrencia e idempotencia), modelo de datos, diagrama de estados y secuencia de reserva concurrente, alineados con ADR-001 y el contrato OpenAPI.

Prompt enviado

soy edier, qué tengo que hacer?

Seguido de «si» para empezar por la parte de G2. Decisión de Edier antes de redactar, ante una pregunta de la IA: control de concurrencia mediante bloqueo pesimista (SELECT … FOR UPDATE).

Salida relevante

• docs/adr/ADR-002-transacciones-idempotencia.md: compara cuatro estrategias de concurrencia y tres almacenes de idempotencia; decide bloqueo pesimista en orden fijo, tabla de idempotencia en la misma transacción con bloqueo consultivo por clave, retención de 24 h y restricciones CHECK en la base. Resuelve H-E01 (fallo antes del commit → 500 sin registro), H-E02 (carrera despacho/cancelación) y H-E03 (409 guardado).

• docs/architecture/datos.md: diagrama entidad-relación de 9 tablas con restricciones e índices.

• docs/architecture/estados.md: diagrama de estados, matriz de transiciones (permitidas y 409) y efectos con el oráculo 10/7/3.

• docs/architecture/secuencia-reserva-concurrente.md: secuencia de dos reservas simultáneas con resultado final 10/7/3.

• Observación H-E05 sobre el contrato: las descripciones de dispatch, deliver y cancel mencionan una clave de idempotencia que esas operaciones no usan.

Decisión humana

Registrada por Edier tras revisar cada archivo:

Cambio	Decisión de Edier (aceptada / corregida / descartada)	Motivo	Fecha UTC
ADR-002	Aceptada	En la reserva, el paso 10 comprueba todas las líneas antes de escribir y el paso 11 solo actualiza si todas cumplen: coincide con «todas o ninguna» (RF05, p. 4)	2026-10-14
Modelo de datos	Aceptada	inventory_items tiene reservado <= fisico y ambos >= 0	2026-10-14
Diagrama de estados	Aceptada	Cancela solo el Solicitante dueño y la entrega la registra el Coordinador, igual que la matriz del §2 (p. 3)	2026-10-14
Secuencia de reserva concurrente	Aceptada	Resultado final 10 / 7 / 3, igual que acceptance-oracles. md	2026-10-14

Verificación

Ejecutada por el asistente en su espacio de trabajo el 2026-10-14:

• Los tres diagramas Mermaid se renderizaron sin errores con @mermaid-js/mermaid-cli 11.4.2. El primer intento de la secuencia falló porque los ; dentro de los mensajes se interpretan como separadores; se reemplazaron por comas.

• Las cantidades del diagrama de estados y de la secuencia coinciden con acceptance-oracles.md (10/7/3, 10/0/10 y 3/0/3).

• Rutas, cabecera Idempotency-Key y política 200/409 comparadas con contracts/openapi.yaml (e63ebf5).

Verificación humana pendiente: Edier debe revisar los diagramas en GitHub y comprobar las reglas contra la p. 4 del enunciado.

Límites

Nada se implementó ni se ejecutó contra PostgreSQL. El comportamiento de FOR UPDATE en READ COMMITTED y el reintento de deadlocks de Laravel deben confirmarse con las pruebas de concurrencia. Sin datos reales ni secretos.

AI-006-revisiones-g2-vega

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

• ID y fecha UTC: AI-006, 2026-10-14T17:43Z a 18:05Z (aprox.)

• Autor: Vega José (202321256198)

• Etapa: revisión crítica (G2)

• Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai

• RF y AC: RF05, RF07, RF09, RNF02; AC-03-03, AC-03-08, AC-03-12

• Contexto y versiones de archivos: PR #8 de Edier (68eab81: ADR-002, datos, estados y secuencia de reserva); revisión de Edier al PR #4 con el hallazgo R-E01; docs/testing/estrategia-pruebas.md v0.1 (a13aa17);

contracts/openapi.yaml (e63ebf5)

Objetivo

Guiar la revisión de Vega al PR #8 de Edier y corregir en la estrategia de pruebas el hallazgo R-E01 que Edier encontró en el PR #4.

Prompt enviado

Soy Vega, tengo que revisar el PR #8 de Edier y demas cosas, guiame en la revisión. Si me ves equivocado en algo corrigeme.

Salida relevante

• Cuatro comprobaciones para el PR #8: orden de autenticación y autorización antes de la clave, respuestas guardadas frente al OpenAPI, restricción UNIQUE de idempotencia y matriz de estados.

• Corrección señalada a Vega: en la comprobación 2 había citado solo el ADR-002 sin compararlo con el OpenAPI; la verificó después con git show … | Select-String "name: Idempotency-Key".

• Borrador del comentario de revisión del PR #8.

• estrategia-pruebas.md v0.2: la fila de concurrencia exige dos procesos PHP independientes y prohíbe php artisan serve con su configuración por defecto (R-E01). Se añadió que PHP_CLI_SERVER_WORKERS no funciona en Windows.

Decisión humana

Cambio	Decisión de Vega (aceptada / corregida / descartada)	Motivo	Fecha UTC
Revisión del PR #8	Aceptada	Comprobó los cuatro puntos en los archivos del PR y el parámetro Idempotency-Key del OpenAPI; coinciden	2026-10-14
Corrección R-E01 en la estrategia de pruebas	Aprobada	Revisé la fila de concurrencia: ya no usa php artisnan serve por defecto y la opción (a) funciona en Windows	2026-10-14

Verificación

• Salida del comando de Vega: el OpenAPI dice «Guardar 200 y 409 de negocio al menos 24h; no guardar 401/403/404/422/500», igual que el ADR-002.

• La versión 0.1 de la estrategia en este espacio de trabajo es idéntica a la publicada en a13aa17 antes de editarla.

Límites

Ninguna prueba de concurrencia se ha ejecutado; la opción elegida se valida al implementar. Sin datos reales ni secretos.

AI-007-frontend-provisional

AI-007 — Frontend e integración provisional

Fecha: 2026-10-14. Herramienta: Codex. Solicitante: coordinador del proyecto; instrucción «haz esto con lo que hay después corrijo», frontend/API y verificación real. No se atribuye revisión humana a una persona distinta del solicitante.

Entradas: SPECS y contratos consolidados, arquitectura Laravel + PostgreSQL y requisitos publicados en docs/examen-oficial. Salida: aplicación apps/nexo, Docker, pruebas PostgreSQL/E2E y flujo CI, informes y PDF provisional.

Decisión técnica propuesta: conservar monolito modular y permisos en servidor, sesiones con CSRF, bloqueos de filas e idempotencia transaccional. Interfaz consume API y presenta acciones por rol. El fallback IA está marcado explícitamente y no reemplaza la evidencia de un LLM real.

Verificación ejecutada por el agente: consultar docs/evidence/runtime/verification.md, JUnit, navegador y enlaces CI. No equivale a firma, aceptación ni revisión humana independiente. Se corrigieron conexión de runtime, refresco del formulario, arnés E2E y dependencia de fuentes externas observados en ejecución.

Riesgos: adelantar implementación no subsana el gate previo del examen. Pendientes: revisor humano sobre SHA, proveedor IA y validador, carga, cobertura completa, aceptación manual y aportes personales verificables. No se crea release-examen.

Validación humana de esta salida: pendiente de publicación por cada autor desde su cuenta. Decisión: propuesta provisional; no aprobado por el equipo.

5. Validación, trazabilidad y resultados

Ocho pruebas PHP correctas no significan 73 criterios aceptados. Los resultados se vinculan a sus versiones; no se trasladan automáticamente a una versión posterior.

Prueba / versión	Esperado	Observado y evidencia
PostgreSQL, corrección dd806db	Historial propio sin error; sin fuga entre dueños u organizaciones	8 correctas, 67 aserciones, 1,47 s; phpunit-audit.xml
Pint, corrección dd806db	Estilo conforme	35 archivos correctos
E2E, candidato f33183a	Entrega, teclado, rechazo y CSRF a 390/1366	4 correctas, 1,6 min; playwright.json
Concurrencia HTTP, f33183a	Dos reservas de 3 con físico 4: una gana	200/409; un RESERVE; stock 4/3/1; cancelar restaura 4/0/4
CI, f33183a	Suite relacional, navegador, concurrencia y documentos	Success: runs 38631036099 y 38631043185
Documentos y contrato	Fuentes coherentes y OpenAPI válido	14 pruebas documentales; 20 rutas / 22 operaciones
LLM real / carga / restauración	Evidencia de operación y objetivos del examen	Pendiente; no se declara superado

Entorno observado: Windows, Docker con Linux, PHP 8.5.0, Laravel fijado en composer.lock, PostgreSQL 17.6, Node 22.22.2 y Playwright 1.56.1. La suite relacional utiliza nexo_test, separada de nexo de demostración. CI se ejecutó en Ubuntu. Los intentos interrumpidos con Edge no se contabilizan como suite correcta; la ejecución completa anterior utilizó Chromium aislado.

5.1 Defecto observado y corrección

Corrección de auditoría del Solicitante

Fecha: 2026-10-14. Ejecución y corrección por Codex a partir de captura aportada por el coordinador.

Síntoma: GET /api/audit devolvía HTTP 500 para Solicitante. El log sanitizado registraba QueryException con correlationId 76e883cf-411d-4497-a03f-508adb626704.

Causa: audit_events.resource_id es texto y requests.id es UUID; la subconsulta IN comparaba tipos distintos en PostgreSQL. Se convierte el ID de la subconsulta a texto, manteniendo el filtro de dueño y organización. No se modifica el esquema ni se amplían permisos.

Verificación real: suite PostgreSQL en nexo_test, 8 pruebas correctas y 67 aserciones, 1,47 s. Nueva regresión: historial propio devuelve 200 y un evento; el de otro dueño de la misma organización devuelve 403; otro Solicitante de ORG-B obtiene lista vacía. Reporte phpunit-audit.xml. Pint Linux correcto en 35 archivos.

Esta corrección posterior no convierte las pruebas anteriores en pruebas de esta versión ni aprueba G1/G2.

5.2 Trazabilidad SPEC frente a código

SPEC	Código relacionado	Límite de la evidencia
SPEC-01 (14 AC)	Identity / middleware	Escenarios parciales ejecutados; aceptación completa pendiente

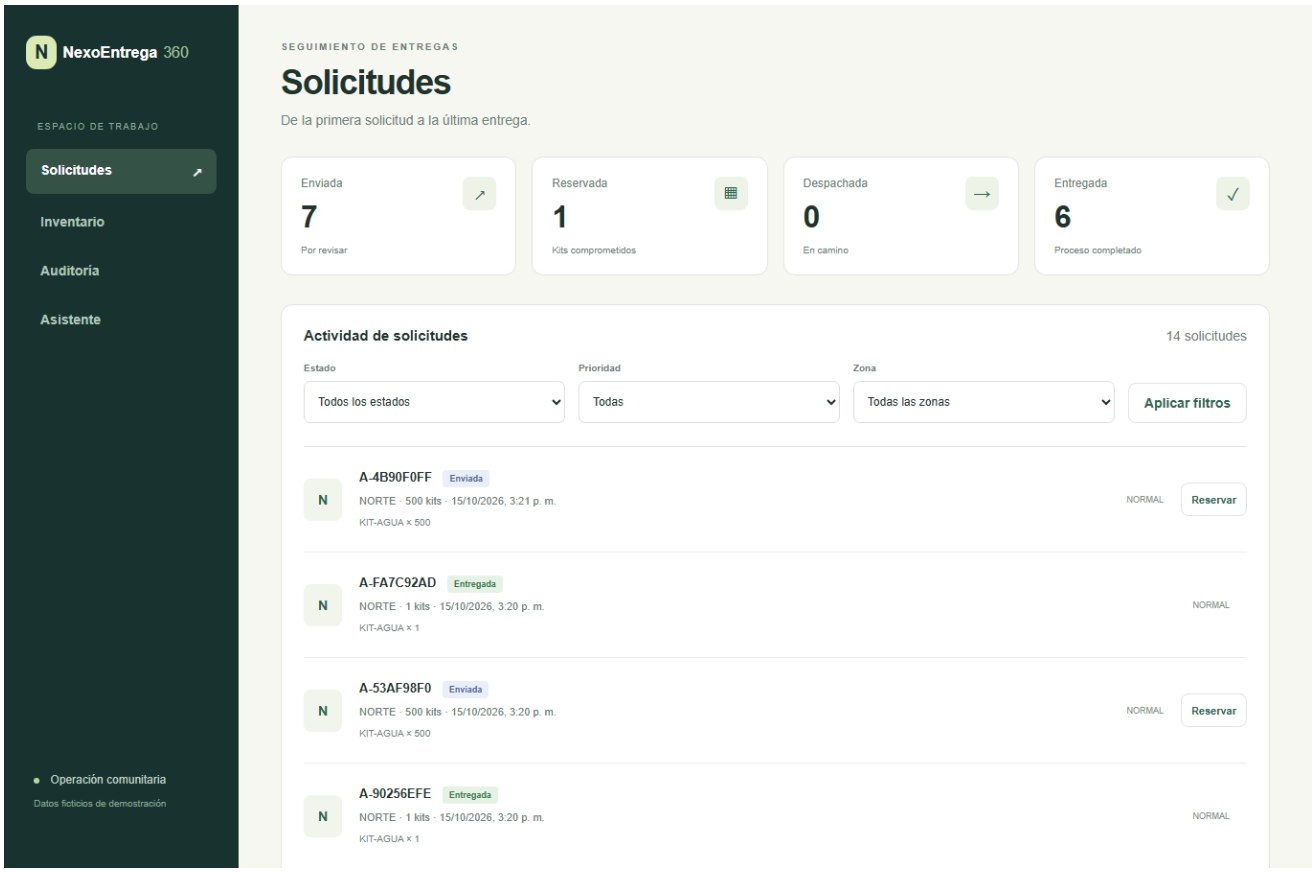
SPEC	Código relacionado	Límite de la evidencia
SPEC-02 (11 AC)	Requests / interfaz	Escenarios parciales ejecutados; aceptación completa pendiente
SPEC-03 (17 AC)	Inventory / transacciones	Escenarios parciales ejecutados; aceptación completa pendiente
SPEC-04 (14 AC)	Queries / interfaz	Escenarios parciales ejecutados; aceptación completa pendiente
SPEC-05 (17 AC)	AI / fallback	Escenarios parciales ejecutados; aceptación completa pendiente

La matriz completa de 73 AC se conserva en docs/evidence/runtime/spec-vs-code.csv, con estado NOT_VERIFIED_IN_FULL. Cada AC completo está descrito en el apartado 2. La matriz documental enlaza pruebas planificadas; solo los reportes ejecutados acreditan resultados observados.

Fuente: docs/evidence/runtime/spec-vs-code.csv

Fuente: docs/coverage-matrix.md

Fuente: docs/evidence/runtime/verification.md



Captura real anterior a la corrección de auditoría; datos ficticios. 1366 px.



Captura real anterior a la corrección de auditoría; datos ficticios. 390 px.

6. Riesgos y controles

La siguiente lectura conserva los riesgos registrados y distingue controles observados de pendientes. Las personas propuestas no se consideran autoras de trabajo no realizado; el riesgo residual requiere evaluación humana.

Riesgo	Prob. / impacto	Control documentado
R-01 · Reserva duplicada por concurrencia	Alta / Alta	Bloqueo/transacción y test con dos usuarios simultáneos
R-02 · Acceso interorganización	Alta / Alta	Filtro de servidor y 2 lecturas + 2 escrituras cruzadas
R-03 · Reutilización indebida de idempotencia	Media / Alta	Scope por usuario/organización/operación/hash y tests
R-04 · Respuesta IA con ID ajeno/inyección	Media / Alta	Schema estricto, whitelist IDs, texto no ejecutable
R-05 · Fallo de proveedor de IA	Alta / Media	Timeout 5 s, resumen alternativo determinista
R-06 · Entrega irreproducible	Media / Alta	Lockfiles, migraciones y clon limpio verificado
R-07 · Ausencia de enunciado y anexos	Baja (fuente recibida 2026-10-14) / Alta	Originales en docs/examen-oficial/ con SHA-256; cotejo en cotejo-oficial-G1.md
R-08 · Implementar antes de revisión humana	Media / Alta	Gate con SHA y autor/revisor distintos; no merge automático
R-09 · Métricas o contribuciones ficticias	Media / Alta	Evidencia real, observado separado de esperado; no suplantar identidades
R-10 · Accesibilidad y rendimiento insuficientes	Media / Media	Teclado, 390/1366px y carga 20VU/60s con 2.000 solicitudes
R-11 · Auditoría y negocio divergen	Media / Alta	Misma transacción y fallo inducido antes del commit
R-12 · Permisos no definidos por la matriz oficial (CL-16, CL-17, CL-18) sin respuesta del docente	Media / Media	Enviar preguntas; aplicar supuesto provisional registrado y aislar su impacto en AC-04-10 y E2E

Actualización de lectura: hay evidencia parcial de reserva, aislamiento, idempotencia y ejecución; el material oficial ya está recibido y CL-16/17/18 cuentan con respuesta reportada. El registro fuente contiene textos históricos pendientes de armonización. Se mantiene alto el riesgo de proceso por cierre humano pendiente; IA, carga y recuperación siguen sin aceptación completa.

Fuente: docs/risks/risk-register.md

7. Ejecución reproducible y recuperación

Ejecución y entrega provisional

Estado: aplicación en desarrollo solicitada por el coordinador antes del cierre de revisiones. No constituye G1/G2 aprobado ni aceptación final. Usa exclusivamente cuentas/datos ficticios.

Arranque con PostgreSQL real

Requisitos: Docker Desktop activo (Linux containers), Git; Node 22 para tests de navegador. Desde la raíz:

```
docker compose up -d --build
```

Abrir http://localhost:8000. Primer arranque instala dependencias fijadas, genera APP_KEY local, migra y siembra si no existen organizaciones. Reiniciar no elimina solicitudes ni vuelve a sembrar. La base persiste en volumen nexo_data. No usar down -v sobre datos que se quieran conservar.

Servicios: GET /health confirma proceso; GET /ready comprueba base y tabla final de migración. La IA no participa en readiness. Aplicación usa servidor PHP de desarrollo con varios workers; no es despliegue de producción. Contraseña PostgreSQL incluida es ficticia y solo para evaluación local; puerto DB no se publica al host.

Cuentas ficticias

Contraseña de las ocho cuentas: DemoNexo360!. Logins: org-a-solicitante@example.test, org-a-coordinador@example.test, org-a-bodega@example.test, org-a-auditor@example.test, y los cuatro equivalentes org-b-…. Rol y organización vienen del servidor tras autenticar, no de un selector de permisos. Para regenerar datos usar una base nueva de evaluación, migraciones y db:seed; no borrar una base compartida para hacer una demo.

Recorrido: Solicitante crea borrador con fecha futura y envía → Coordinador reserva → Bodega despacha → Coordinador registra entrega → Auditor consulta historial. Cancelación pertenece al Solicitante dueño. Stock se actualiza en API; interfaz no calcula ni persiste decisiones de inventario. El catálogo solo expone nombres SKU activos propios, sin cantidades para Solicitante.

Verificación

Crear base de pruebas independiente nexo_test en PostgreSQL del contenedor antes de la suite; no ejecutar tests sobre nexo de demostración:

```
docker compose exec database psql -U nexo -d postgres -c "CREATE DATABASE nexo_test"
```

```
docker compose exec -e APP_ENV=testing -e DB_DATABASE=nexo_test app php artisan test
```

```
npm ci
```

```
npx playwright install chromium
```

```
npm run test:e2e
```

Crear la base solo si no existe. Los tests HTTP de Laravel usan una base real para comprobar efectos; su middleware CSRF se omite por modo testing del framework y se comprueba externamente con navegador. Los E2E operan sobre la demo y añaden solicitudes ficticias; cada ejecución consume algunas existencias. Usar entorno de evaluación limpio dedicado, no datos compartidos, al repetir todos los escenarios.

Playwright utiliza su Chromium aislado; para probar Edge adicionalmente, definir E2E_CHANNEL=msedge antes de ejecutar. Capturas/trazas/reporte se generan en test-results y playwright-report (ignorados en Git); seleccionar evidencia sanitizada para docs/evidence/runtime. La verificación por teclado automatizada no equivale a conformidad WCAG ni sustituye revisión manual.

Operación, rollback y brechas

docker compose logs app y docker compose exec app cat storage/logs/nexo.log: logs JSON con correlationId, status y ruta patrón; no cuerpo/credenciales/tokens. No guardar dumps de sesión ni APP_KEY en evidencias. Mantener .env fuera de Git.

Para detener sin borrar datos: docker compose stop. Antes de modificar migraciones, crear backup pg_dump y probar restauración en otra base. Una imagen anterior de aplicación solo debe levantarse si es compatible con el esquema actual. Esta versión crea esquema inicial: no prometer rollback de datos mediante migrate:rollback; restaura solo un backup verificado en base nueva y cambia conexión tras comprobarlo. No se declara restauración probada hasta ejecutarla.

IA provisional: fallback determinista visible, aprobación con auditoría y sin inventario. Pendientes: proveedor real/replay y validador completo de salida IA, carga 20VU/60s, trazabilidad de todos AC, secret scan, revisión independiente y gates. Reportes de ejecución se registran separadamente. No crear release-examen ni declarar aceptación completa mientras existan incumplimientos.

7.1 Corrección de auditoría en la instancia local

La instancia local recibió QueryController corregido sin modificar datos ni esquema. Un arranque limpio debe reconstruir la imagen desde el código identificado en esta edición. Verificar historial del Solicitante tras iniciar sesión. Las contraseñas expuestas en el runbook son exclusivamente ficticias de demostración.

8. Aceptación y pendientes verificables

Acta provisional: entrega no aceptada como final

La implementación de esta rama se adelantó por instrucción expresa del coordinador «haz esto con lo que hay, después corrijo». Esto no equivale a aprobación G1/G2 ni elimina la exigencia de revisión previa del examen. La brecha de proceso se mantiene visible y el código requiere revisión independiente antes de integración.

Alcance: frontend y API locales para ocho cuentas ficticias, solicitudes, flujo de stock, consultas y auditoría. Asistente actualmente con fallback determinista declarado; no se atribuye una invocación a LLM real.

Estado de aceptación: PROVISIONAL / NO ACEPTADO COMO ENTREGA FINAL. El informe de ejecución consigna qué pruebas se ejecutaron y sus resultados. Revisor independiente, fecha de aceptación, firmas y decisiones finales: pendientes.

Brechas antes de release-examen: proveedor/reproducción real y validación completa IA, pruebas por todos los AC, carga exigida, escenarios adicionales de concurrencia/fallos/TTL, restauración y aceptación manual, aportes personales de código/pruebas de todos, convergencia y revisión humana final. Ya existen suite PostgreSQL, E2E responsive, un escenario concurrente, revisión automatizada limitada de secretos/dependencias y CI remoto correctos sobre el candidato indicado en verification.md; no prueban todos los requisitos. No generar aprobación ficticia ni tag release-examen para esconder brechas.

El PDF consolidado provisional permite revisar el estado; los cuatro deben entregar el mismo PDF final después de corregir y verificar esas brechas, no cuatro versiones distintas.

Coordinación de la entrega

Paquete actual: provisional; PR #12 en borrador. Cualquier aprobación debe identificar el SHA revisado y venir de la persona que revisó.

Responsable propuesto	Acción ejecutable	Evidencia requerida
Conde José	Abrir runbook, levantar Docker, recorrer desde solicitud hasta entrega y probar rechazo; revisar aporte ajeno	Comentario propio con SHA, pasos, resultado y decisión; PR de su corrección o prueba real
Carolina	Contrastar formularios, estados y errores contra las cinco SPECS, comprobar teclado y 390/1366	Hallazgos reproducibles y revisión personal del SHA; prueba/corrección propia
Edier	Revisar bloqueos, transacciones, reserva parcial, idempotencia/TTL, aislamiento y restauración	Tests PostgreSQL adicionales, resultados y revisión del código de otro integrante
Vega	Completar LLM real y validación estricta con evidencias, revisar seguridad/CI/carga	PR con pruebas de salida válida/inválida, fallo/fallback, carga y CI real; revisión cruzada

1. Publicar correcciones en PR separados; cada integrante aporta código o pruebas y revisa un aporte ajeno, sin autoaprobarse.

2. Registrar cierre G1/G2 y decisiones sobre SHA exactos. Resolver la brecha de proceso ante el equipo; no inventar revisión previa.

3. Ejecutar en entorno limpio dedicado el mismo candidato: suite PostgreSQL, E2E, concurrencia, validación IA real, carga exigida, dependencias/secretos, backup/restauración y aceptación manual. Guardar resultados, entorno y fallos.

4. Completar comparación de los 73 AC contra código y evidencia. Un enlace a una prueba planificada no acredita que haya pasado.

5. Regenerar el PDF común desde el candidato: cinco historias/SPECS, arquitectura/modelo/contratos, IA/verificación humana, trazabilidad/riesgos, pruebas/CI/ejecución/aceptación y contribuciones reales. Revisar el contenido completo con anexo 09 y la rúbrica.

6. Solo tras aceptación real, registrar SHA final, crear y publicar release-examen apuntando a ese commit; comprobar remotamente el tag. Verificar hash SHA-256 del PDF y que los cuatro adjunten el mismo archivo Examen_SDD_IA_Equipo_NexoEntrega360.pdf al aula.

Generación provisional reproducible: instalar docs/delivery/requirements-pdf.lock y ejecutar python scripts/export_delivery_pdf.py --sha <SHA-candidato>. El documento se rotula provisional. No sustituye la revisión final ni publica nada en el aula.

Revisor humano: pendiente. Fecha UTC de decisión: pendiente. SHA aceptado: pendiente. Observaciones y decisión: deben ser publicadas personalmente por el revisor correspondiente. Esta edición no firma por integrantes ni declara revisiones anteriores a la implementación.

9. Participación y evidencias del equipo

Participación y revisión: evidencia, no atribución por código generado

Persona	Evidencia publicada	Trabajo restante
Carolina	Comentario personal de PR #10 sobre c70e431, SPEC-04/plan/tareas	Aporte real de código/pruebas de aceptación, revisiones de versiones nuevas
Edier	PR #2/#8 y revisiones de PR #3/#4	Backend/tests PostgreSQL y revisión de este código provisional
Vega José	PR #3/#4, revisiones PR #2/#5 y CI documental	Completar proveedor/validación IA, calidad/CI real del producto
Conde José	Coordinación y solicitudes de trabajo; commits de código de esta rama generados por Codex	Verificar personalmente cambios y aportar código/pruebas propios; revisión crítica ajena registrada

No se atribuye a una persona la autoría manual o la ejecución de tests hechos por Codex. Esta implementación fue solicitada provisionalmente por el coordinador; requiere revisión humana independiente y no acredita por sí sola todos los requisitos de participación.

Los enlaces a PR se consultan en el repositorio: #2/#8 (Edier), #3/#4 (Vega), #7/#10 (Carolina y consolidación), #12 (frontend/integración provisional). Las revisiones válidas requieren autor real, SHA y decisión. Las tareas propuestas no acreditan su realización.

Fuente: docs/team/plan-colaboracion.md

Fuentes y control de edición

Esta edición transforma la presentación, sin sustituir las fuentes oficiales ni modificar las cinco SPECS. El Word es editable; si se cambia su contenido, el PDF debe regenerarse y cotejarse para que los cuatro integrantes entreguen el mismo archivo final. La portada no incluye institución, curso o docente no confirmados.